

BP Digital Banking Platform

Documento de Arquitectura de Software (SAD)

Plantilla arc42 — Modelo C4 — Decisiones arquitectónicas clave

Entidad: BP — Banco mediano ecuatoriano

Versión 1.0

Versión final.

Documento controlado — Distribución interna

Autor: Edgar Changoluisa

Rol: Arquitecto de Soluciones

Fecha de emisión: 26/05/2026

Contenido

Historial de Versiones	4
Resumen Ejecutivo.....	5
1. Introducción y Objetivos.....	6
1.1. Visión general de requisitos	6
1.1.1. Capacidades funcionales del MVP	6
1.1.2. Capacidades fuera del alcance (roadmap)	7
1.1.3. Matriz de trazabilidad del enunciado	8
1.2. Objetivos de Calidad	9
1.3. Stakeholders	10
2. Restricciones de Arquitectura.....	11
2.1. Restricciones Técnicas	11
2.2. Restricciones Organizacionales	12
2.3. Restricciones Regulatorias.....	12
3. Contexto y Alcance del Sistema	15
3.1. Contexto de Negocio	15
3.1.1. Actores y sistemas identificados	17
3.1.2. Relaciones y protocolos.....	18
3.2. Contexto Técnico	19
3.2.1. Interfaces con actores humanos	19
3.2.2. Interfaces con sistemas internos del banco	19
3.2.3. Interfaces con sistemas externos regulatorios.....	20
3.2.4. Interfaces con proveedores externos.....	20
4. Estrategia de Solución.....	21
4.1. Frase guía del documento	21
4.2. Decisiones tecnológicas fundamentales.....	21
4.2.1. Comparativa Frontend: SPA Web y App Móvil.....	22
4.2.2. Flujo de autenticación OAuth 2.0 recomendado	24
4.2.3. Patrón de diseño para clientes frecuentes: Cache-Aside	24
4.3. Descomposición de alto nivel	25
4.3.1. Canales Digitales.....	25
4.3.2. Identidad y Seguridad.....	25
4.3.3. Onboarding Biométrico	26
4.3.4. Perfil y Posición Consolidada	26
4.3.5. Movimientos y Estados de Cuenta	27
4.3.6. Transferencias y Pagos	27

4.3.7. Riesgo, Límites y Cumplimiento	27
4.3.8. Notificaciones	27
4.3.9. Auditoría	27
4.3.10. Integración.....	28
4.4. Cómo se atienden los objetivos de calidad	29
5. Vista de Bloques de Construcción.....	30
5.1. Whitebox del sistema completo (C4 Nivel 2 — Contenedores)	30
5.2. Nivel de componentes (C4 Nivel 3)	34
6. Vista de Tiempo de Ejecución	41
6.1. Flujo resumido de Onboarding Biométrico	41
6.2. Flujo resumido de Transferencia Interbancaria.....	41
6.3. Flujo resumido de Autenticación OAuth2/OIDC.....	42
7. Vista de Despliegue.....	43
7.1. Infraestructura AWS — Visión general	43
7.2. Multi-AZ y Estrategia de Recuperación ante Desastres.....	43
8. Conceptos Transversales	44
8.1. Seguridad	44
8.2. Alta Disponibilidad y Recuperación ante Desastres	44
8.3. Observabilidad.....	45
8.4. Optimización de Costos (FinOps).....	45
8.5. Gestión de Datos y Patrones de Persistencia	45
8.6. Cumplimiento Operativo	46
9. Decisiones arquitectónicas clave	47
Decisión 1 — Monolito modular con servicios extraídos	47
Decisión 2 — AWS ECS Fargate para el MVP	47
Decisión 3 — Mensajería con AWS SQS y SNS.....	47
Decisión 4 — Patrón BFF para la SPA Web	48
Decisión 5 — React + TypeScript en web; Flutter en móvil.....	48
Decisión 6 — OAuth 2.0 Authorization Code con PKCE.....	48
Decisión 7 — Patrón Saga para transferencias.....	49
Decisión 8 — Cache-Aside para clientes frecuentes.....	49
10. Requisitos de calidad considerados	50
11. Riesgos identificados.....	50
12. Glosario.....	51

Historial de Versiones

Este documento es controlado y versionado. Cada cambio queda registrado en la tabla siguiente, indicando versión, fecha, autor, descripción y estado. Las versiones menores (0.x) representan iteraciones de trabajo previas a aprobación; la versión 1.0 corresponde a la primera revisión completa entregada formalmente.

Versión	Fecha	Autor	Descripción del cambio	Estado
0.1	26/05/2026	EChangoluisa	Borrador inicial. Definición de alcance, objetivos, restricciones y normativa aplicable.	Borrador
0.5	26/05/2026	EChangoluisa	Estrategia de solución, descomposición funcional, índice de decisiones arquitectónicas clave y glosario. Reestructuración bajo plantilla arc42.	Borrador avanzado
0.9	26/05/2026	EChangoluisa	Versión candidata a entrega. Incorpora estructura SAD, matriz de trazabilidad, alcance MVP, restricciones, decisiones arquitectónicas, decisiones arquitectónicas clave principales y descriptores de las vistas C4, despliegue, runtime y conceptos transversales.	Candidato a entrega
1.0	26/05/2026	EChangoluisa	Versión final académica. Integra diagramas C4, tablas de soporte, decisiones arquitectónicas clave, vista runtime resumida, despliegue AWS/híbrido, seguridad, HA/DR, monitoreo, costos y riesgos.	Final académico

Convenciones del documento:

- Algunas secciones se documentan en nivel ejecutivo para mantener el documento proporcional al alcance del ejercicio. Los artefactos complementarios se conservan en el repositorio como respaldo técnico.
- Las referencias normativas citan la resolución, fecha y entidad emisora cuando corresponda.
- Los diagramas se entregan en formato draw.io (.drawio) y con su código equivalente Mermaid.js incluido en el repositorio del proyecto.

Resumen Ejecutivo

BP es un banco mediano del Ecuador y necesita una plataforma de banca digital, web y móvil, donde sus clientes puedan ver su posición consolidada, consultar el histórico de movimientos, hacer pagos y ejecutar transferencias entre cuentas propias e interbancarias. Todo eso sobre una base segura, auditable y alineada con la normativa vigente en el país.

La propuesta de este SAD no pretende reemplazar el Core Bancario actual. Sobre él se construye una capa digital nueva, segura y desacoplada, que se integra con el Core, el sistema complementario del cliente, los sistemas del BCE (SPI, SPL, SCI y el nuevo esquema de interoperabilidad en tiempo real de la Resolución BCE-GG-008-2025), el proveedor biométrico para el onboarding y los proveedores de notificación.

La decisión de fondo es conservadora a propósito. Se usa un monolito modular como núcleo del backend y se extraen como servicios separados solo aquellos casos donde la separación se justifica con criterio claro: Onboarding biométrico, Transferencias interbancarias, Notificaciones y Auditoría. El antifraude se queda como componente transversal dentro del monolito, con su interfaz bien definida; cuando aparezca otro canal que lo consuma (cajeros, POS, banca empresarial), se extrae sin reescribir nada.

La meta no es que la arquitectura se vea ambiciosa. La meta es que cada pieza tenga su razón. En banca, una solución simple, trazable y operable suele ser más defendible que una arquitectura sobredimensionada. Por eso este diseño prioriza operación simple, control del gasto en nube, cumplimiento normativo y evolución gobernada con umbrales explícitos.

En tecnología las decisiones principales son: SPA Web en React 18 + TypeScript con patrón Backend-Frontend (BFF); aplicación móvil en Flutter, con OAuth2/OIDC vía navegador externo del sistema (RFC 8252) y almacenamiento seguro en Keychain/Keystore; backend en Spring Boot 3 sobre AWS ECS Fargate en sa-east-1, con DR en us-east-1; mensajería asíncrona vía SQS/SNS, API Gateway perimetral en AWS y una capa Anti-Corruption Layer hacia el Core que vive on-premise.

El marco normativo que aplica al diseño es: LOPDP para datos personales, Resolución SB-2021-2126 de la Superintendencia de Bancos para riesgo operativo, normativa UAFE vigente para los reportes RESU y ROS, Resolución JPRM-2024-029-M y BCE-GG-008-2025 para interoperabilidad de pagos en tiempo real. Como referentes técnicos internacionales se consideran OWASP ASVS 4.0, ISO/IEC 27001, ISO/IEC 30107-3, PCI DSS 4.0, OAuth 2.1 y RFC 8252.

El documento sigue la plantilla arc42 para organizar el SAD y usa el modelo C4 para los diagramas. arc42 dice qué documentar; C4 dice cómo diagramarlo. Son marcos complementarios, no excluyentes. Esta combinación es una práctica común en documentación de arquitectura porque C4 aporta claridad visual y arc42 aporta orden documental.

Una aclaración antes de seguir: el enunciado pide explícitamente el modelo C4. Eso se respeta. arc42 no lo reemplaza, lo envuelve. C4 cubre los diagramas de Contexto, Contenedores y Componentes que la prueba califica; arc42 ordena el documento alrededor de esos diagramas para que sea defendible en un comité técnico real.

1. Introducción y Objetivos

Esta sección establece el marco de referencia del sistema BP Digital Banking Platform: el problema que resuelve, los requisitos funcionales y de calidad que debe cumplir, y los stakeholders involucrados. Conforme al estándar arc42, esta sección responde a las preguntas fundamentales que debe entender cualquier persona que lea el documento, independientemente de su perfil técnico.

1.1. Visión general de requisitos

BP requiere implementar una solución de banca por internet y banca móvil que permita a sus clientes consultar información financiera, acceder al histórico de movimientos, realizar pagos, ejecutar transferencias entre cuentas propias e interbancarias, recibir notificaciones obligatorias y operar de forma segura desde canales digitales.

La solución debe integrarse con dos fuentes principales de información: una plataforma Core Bancaria, que contiene los datos básicos del cliente, productos, saldos y movimientos; y un sistema complementario de cliente, que mantiene información extendida requerida para procesos específicos cuando los datos se necesitan en detalle.

El reto arquitectónico no consiste en reemplazar el Core Bancario, sino en construir una capa digital segura, desacoplada y escalable sobre los sistemas existentes. Por tanto, las aplicaciones web y móvil no accederán directamente al Core, sino mediante una capa de integración gobernada por API Gateway, servicios de negocio, controles de seguridad, auditoría y monitoreo.

1.1.1. Capacidades funcionales del MVP

El alcance del MVP cubre las siguientes capacidades funcionales. La inclusión o exclusión de cada capacidad responde a los requisitos explícitos del enunciado y al criterio profesional de no inflar el alcance más allá de lo defendible.

Capacidad	MVP	Justificación
SPA Web (React + TypeScript)	Sí	Requerido por el enunciado.
App móvil multiplataforma (Flutter)	Sí	Requerido por el enunciado.
OAuth2/OIDC con producto corporativo	Sí	Requerido por el enunciado.
Onboarding biométrico con reconocimiento facial	Sí	Requerido por el enunciado.
Posición consolidada del cliente	Sí	Necesaria para experiencia bancaria real.
Consulta de movimientos e histórico	Sí	Requerido por el enunciado.
Estados de cuenta en PDF/CSV	Sí, básico	Extensión natural del histórico.
Transferencias entre cuentas propias	Sí	Requerido por el enunciado.

Transferencias a terceros dentro de BP	Sí	Requerido por el enunciado.
Transferencias interbancarias (SPI/SPL/SCI/Interop)	Sí	Requerido por el enunciado.
Pagos de servicios	Sí	Requerido como dominio de pagos.
Pagos de tarjetas y préstamos propios	Sí, básico	Pago de productos financieros del banco.
Beneficiarios frecuentes	Sí	Mejora seguridad y experiencia de usuario.
Cupos y límites por canal	Sí	Seguridad transaccional.
Motor antifraude transaccional	Sí	Necesario para banca digital.
Controles ALA/CFT (UAFE)	Sí	Necesario por normativa.
Notificaciones multicanal (mínimo 2)	Sí	Requerido por el enunciado.
Auditoría de acciones del cliente	Sí	Requerido por el enunciado.

1.1.2. Capacidades fuera del alcance (roadmap)

Las siguientes capacidades quedan explícitamente fuera del MVP. La arquitectura, sin embargo, se diseña modular y extensible para incorporarlas en fases posteriores sin rehacer la base tecnológica:

- Depósitos y retiros físicos.
- Cajeros automáticos y corresponsales no bancarios.
- Cash-out sin tarjeta.
- Banca empresarial (perfiles de firmas conjuntas, conciliación masiva, archivos por lote).
- Originación completa de créditos.
- Inversiones.
- Gestión de reclamos.
- Open Finance / Open Banking.

El alcance del MVP se centra en banca por internet y banca móvil para consulta de posición consolidada, movimientos históricos, pagos, transferencias, onboarding biométrico, autenticación segura, auditoría, notificaciones y controles transaccionales. Funcionalidades como depósitos físicos, retiros, cajeros automáticos, corresponsales no bancarios, originación completa de créditos, inversiones, banca empresarial y Open Finance se consideran fuera del MVP. Sin embargo, la arquitectura se diseña modular y extensible para incorporarlas en fases posteriores sin rehacer la base tecnológica.

1.1.3. Matriz de trazabilidad del enunciado

La siguiente tabla la uso como checklist para verificar que los puntos del enunciado estén cubiertos. No es una matriz académica; es un mapa práctico para que el lector encuentre rápido dónde se aborda cada requerimiento.

Requerimiento del enunciado	Sección que lo cubre	Evidencia / Componente
Acceso al histórico de movimientos	Sección 4.3.5, Sección 5.1, Sección 5.2	Módulo Movimientos y Estados de Cuenta.
Transferencias entre cuentas propias e interbancarias	Sección 4.3.6, Sección 6.2, Decisión 7	Servicio de Transferencias + adaptadores BCE + Saga.
Pagos de servicios y productos financieros	Sección 4.3.6	Dominio de Pagos: servicios básicos, tarjetas y préstamos propios.
Información de cliente desde Core + sistema complementario	Sección 2.1, Sección 3.2, Sección 4.3.10	Capa de Integración con Anti-Corruption Layer.
Notificaciones mínimo 2 canales	Sección 4.3.8, Sección 5.1	Push, email y SMS (tres canales).
SPA + App móvil multiplataforma con 2 opciones evaluadas	Sección 4.2.1, Decisión 5	React vs Angular; Flutter vs React Native.
OAuth 2.0 con recomendación del mejor flujo	Sección 4.2.2, Decisión 6, Sección 6.3	Authorization Code + PKCE justificado frente a otros flujos.
Onboarding facial integrado a autenticación/autorización	Sección 4.3.3, Sección 6.1	Servicio de Onboarding Biométrico + IdP.
Métodos post-onboarding: clave, huella, otros	Sección 4.3.2	Usuario+clave, biometría local (huella/FaceID), OTP, push auth.
Recomendación de herramientas de industria (biometría)	Sección 2.2	FacePhi como opción evaluada; arquitectura abierta a equivalentes.
Base de datos de auditoría de acciones del cliente	Sección 4.3.9, Servicio de Auditoría / Sección 9	Servicio de Auditoría append-only.
Patrón de diseño para clientes frecuentes	Sección 4.2.3	Patrón Cache-Aside con Redis ElastiCache.
API Gateway en capa de integración	Sección 5.1, Sección 7.1	AWS API Gateway + BFF Web.
Servicios mínimos: datos básicos, movimientos, transferencias	Sección 4.3.10	Servicios obligatorios + servicios adicionales propuestos.
Diagrama C4 de Contexto	Sección 3.1	C4 Nivel 1.

Diagrama C4 de Contenedores	Sección 5.1	C4 Nivel 2.
Diagrama C4 de Componentes	Sección 5.2	C4 Nivel 3.
Normativa financiera (LOPD, seguridad, etc.)	Sección 2.3, Sección 8.6	LOPD, SB-2021-2126, UAFE, BCE.
Alta Disponibilidad y Tolerancia a fallos	Sección 7.2, Sección 8.2	Multi-AZ, circuit breakers, auto-healing.
Recuperación ante Desastres (DR)	Sección 7.2	DR activo-pasivo (Pilot Light) us-east-1.
Seguridad	Sección 8.1	OAuth2, MFA, BFF, WAF, KMS, TLS.
Monitoreo y excelencia operativa	Sección 8.3	CloudWatch, X-Ray, dashboards, SLOs.
Manejo de costos (cloud)	Sección 8.4	FinOps, serverless, umbrales de evolución.
Arquitectura desacoplada, reusable, cohesiva	Sección 4.2, Sección 4.3	Monolito modular + servicios extraídos justificados.
Justificación con mínimo 2 razones y opciones evaluadas	Sección 4.2, Sección 9	Tabla de decisiones tecnológicas + decisiones arquitectónicas clave
Repositorio público en GitHub con URL	Anexo de entrega	Repositorio con SAD, diagramas y decisiones clave.

1.2. Objetivos de Calidad

Los siguientes objetivos de calidad guían las decisiones arquitectónicas. Están priorizados de mayor a menor; cuando dos objetivos entran en conflicto, prevalece el de mayor prioridad.

Prioridad	Objetivo de calidad	Motivación
1	Seguridad	Datos financieros, biométricos y de identidad bajo regulación estricta (LOPD, Superbancos, UAFE).
2	Disponibilidad (HA)	Operaciones críticas para el cliente y obligación 24/7 para interoperabilidad BCE.
3	Cumplimiento normativo	El incumplimiento implica sanciones administrativas, civiles e incluso penales.
4	Trazabilidad y auditabilidad	Cada acción del cliente debe ser registrada y reconstruible.
5	Tolerancia a fallos	Falla de proveedores externos (biometría, notificación) no debe tumbar transacciones.
6	Mantenibilidad y evolución	Arquitectura modular preparada para incorporar nuevos canales y productos.

7	Costo operativo	Selección de servicios gestionados y patrones serverless cuando aporten valor.
8	Rendimiento	Latencia perceptible <1s en consultas; <3s en transferencias internas.

1.3. Stakeholders

Los siguientes actores tienen interés directo o indirecto en el sistema. La arquitectura debe atender los intereses de cada uno conforme a su nivel de involucramiento.

Stakeholder	Rol	Interés principal
Cliente final	Usuario de banca web y móvil	Operar de forma rápida, segura y sin fricción innecesaria.
Banco BP — Negocio	Patrocinador	Cumplimiento, retención de clientes, costo controlado.
Banco BP — Tecnología	Operador de la plataforma	Mantenibilidad, observabilidad, recuperación ante fallos.
Banco BP — Seguridad y Cumplimiento	Riesgo y cumplimiento	LOPDP, UAFE, Superbancos, gestión de incidentes.
Superintendencia de Bancos	Regulador	Cumplimiento de SB-2021-2126 y normas conexas.
UAFE	Regulador antilavado	Reportes RESU y ROS, prevención de lavado de activos.
Banco Central del Ecuador	Operador del Sistema Nacional de Pagos	Cumplimiento de SPI/SPL/SCI e interoperabilidad.
Proveedor biométrico	Vendor externo	Integración estable, conformidad ISO/IEC 30107-3 (liveness detection).
Proveedores de notificación	Vendors externos	Integración asíncrona, SLAs definidos.

2. Restricciones de Arquitectura

Las restricciones son condiciones no negociables que limitan el espacio de soluciones. Se clasifican en técnicas, organizacionales y regulatorias. Cualquier decisión arquitectónica posterior debe respetar estas restricciones; las violaciones deben justificarse explícitamente o ser elevadas como excepciones al comité de arquitectura.

2.1. Restricciones Técnicas

Las siguientes restricciones técnicas se derivan del enunciado y de los supuestos arquitectónicos asumidos. Se declaran abiertamente para condicionar la validez de las decisiones posteriores.

Restricción	Decisión / Valor
Tipo de entidad	Banco mediano ecuatoriano ficticio denominado BP.
Volumen estimado de clientes digitales	Entre 250.000 y 600.000 clientes activos.
TPS pico inicial	Entre 100 y 200 transacciones por segundo en horario laboral.
Core Bancario	Existente, on-premise. Se asume acceso vía REST con Anti-Corruption Layer (ACL) para componentes legacy.
Sistema complementario de cliente	Existente, on-premise o red privada de la entidad.
Cloud principal	AWS, región sa-east-1 (São Paulo) por latencia y catálogo gestionado.
Cloud para DR	AWS región us-east-1 (N. Virginia) con estrategia activa-pasiva.
Integración cloud / on-premise	AWS Direct Connect con VPN como respaldo.
Backend	Spring Boot 3.x sobre Java 21 (LTS).
Frontend Web	React 18 + TypeScript.
Aplicación móvil	Flutter multiplataforma (iOS y Android).
Autenticación	OAuth2/OIDC con flujo Authorization Code + PKCE; producto corporativo configurado, no construido.
Estrategia de tokens en SPA	Patrón Backend-For-Frontend (BFF) + cookies HttpOnly/Secure/SameSite=strict.
Estrategia de tokens en móvil	Navegador externo del sistema (RFC 8252) + Keystore/Keychain + biometría local del dispositivo.
Contenedores	AWS ECS Fargate. EKS evaluado y descartado para el MVP por costo y complejidad operativa.

Mensajería asíncrona	AWS SQS/SNS gestionado. Brokers autohospedados descartados por TCO.
Arquitectura base	Monolito modular + servicios especializados con justificación explícita.

2.2. Restricciones Organizacionales

Las restricciones organizacionales reflejan el contexto del equipo y los procesos de la entidad. Aunque BP es un banco ficticio para el ejercicio, las siguientes restricciones reflejan condiciones típicas de un banco mediano ecuatoriano y se asumen como aplicables.

- Existe un Core Bancario consolidado cuya inversión no se reemplaza.
- Existe un producto OAuth2/OIDC corporativo configurable. La autenticación se construye sobre él, no de cero. Para efectos de referencia técnica se considera Keycloak como alternativa viable por costo, control y despliegue privado; el diseño es compatible con ForgeRock, Okta, PingIdentity o una solución corporativa equivalente.
- Se considera un proveedor biométrico especializado para el onboarding facial. Para efectos del diseño se evalúa FacePhi como opción principal por su enfoque en banca y verificación de identidad, sin cerrar la arquitectura a un proveedor específico; cualquier proveedor equivalente certificado bajo ISO/IEC 30107-3 es intercambiable mediante la capa Anti-Corruption Layer.
- El banco cuenta con presupuesto para infraestructura cloud, pero exige criterio de costo-beneficio en cada decisión (principio FinOps).
- El sistema debe poder operarse por un equipo de tecnología de tamaño moderado, sin requerir un equipo SRE dedicado de gran escala en la fase MVP.

2.3. Restricciones Regulatorias

El sector financiero ecuatoriano está sujeto a un marco normativo estricto. Las normas siguientes condicionan directamente decisiones arquitectónicas y operativas, y deben respetarse desde el diseño (privacy by design, security by design, compliance by design).

Norma / Entidad	Impacto arquitectónico
LOPDP — Ley Orgánica de Protección de Datos Personales	Consentimiento informado, minimización, derechos ARCO, cifrado en tránsito y reposo, protección reforzada de datos biométricos, retención limitada.
Superintendencia de Bancos — Resolución SB-2021-2126	Norma de control para la gestión del riesgo operativo. Exige controles sobre procesos, personas, tecnología, eventos externos, fraude, continuidad, seguridad de la información, trazabilidad, monitoreo y gestión de incidentes.
UAFE — Unidad de Análisis Financiero y Económico	El sistema genera eventos para identificar operaciones individuales o acumuladas iguales o superiores a USD 10.000, así como operaciones

	inusuales o sospechosas. Los reportes RESU y ROS se gestionan conforme a los plazos y formatos establecidos por la UAFE vigente.
BCE — Sistema Nacional de Pagos	La arquitectura prevé adaptadores para SPI, SPL, SCI e interoperabilidad BCE. En el MVP se priorizan transferencias interbancarias y pagos en tiempo real conforme al alcance; los demás mecanismos se habilitan según certificación, alcance operativo y evolución regulatoria.
Resolución JPRM-2024-029-M y BCE-GG-008-2025	Interoperabilidad de transferencias electrónicas en tiempo real, homologación de códigos QR, mensajería estandarizada, operación 24/7.
Ley Orgánica de Prevención, Detección y Erradicación del Delito de Lavado de Activos y del Financiamiento de Delitos	Marco legal superior a las resoluciones UAFE; impone obligaciones de oficial de cumplimiento, manual de prevención y reporte oportuno.
OWASP ASVS 4.0	Verificación de seguridad de aplicaciones: autenticación, sesiones, control de acceso, validación de entrada, logging.
OAuth 2.1 / OIDC / RFC 8252	Authorization Code + PKCE para SPA y móvil; navegador externo en apps nativas; BFF recomendado por IETF para SPAs en aplicaciones sensibles.
ISO/IEC 27001 / 27002	Sistema de gestión de seguridad de la información.
ISO/IEC 30107-3	Detección de presentación (liveness detection) para sistemas biométricos.
PCI DSS 4.0	Aplicable únicamente si en el alcance se procesan o transmiten datos de cuenta primaria (PAN). En el MVP no es central; se considera para la evolución.

Texto formal sobre el marco BCE:

La Resolución BCE-GG-008-2025 establece la implementación de interoperabilidad de transferencias electrónicas de dinero para pagos en tiempo real, integrando los sistemas existentes del BCE (SPI, SPL, SCI) y los esquemas de redes de pagos privadas, con homologación de códigos QR, mensajería estandarizada y controles de seguridad, monitoreo, continuidad y DR.

Sobre la Resolución SB-2021-2126: expide la norma de control para la gestión del riesgo operativo aplicable a entidades financieras públicas y privadas bajo vigilancia de la Superintendencia de Bancos. Esta norma justifica que la arquitectura no se limite a pantallas y APIs, sino que incorpore controles explícitos sobre procesos, personas, tecnología, eventos externos, fraude, continuidad, seguridad de la información, trazabilidad, monitoreo y gestión de incidentes.

Sobre el SPI: el Banco Central del Ecuador lo define como el sistema que canaliza transferencias electrónicas de dinero ordenadas por personas, entidades o empresas a través de bancos, cooperativas y mutualistas hacia cuentas de distintas entidades financieras del sistema ecuatoriano.

3. Contexto y Alcance del Sistema

Esta sección delimita los límites del sistema BP Digital Banking Platform respecto de su entorno: qué actores interactúan con el sistema, qué sistemas internos y externos consume o publica, y qué responsabilidades quedan fuera de su control. La vista de contexto queda representado en el Diagrama C4 Nivel 1, que se presenta a continuación junto con la tabla de relaciones y la descripción técnica de cada integración.

3.1. Contexto de Negocio

El diagrama C4 Nivel 1 presenta la vista de contexto de la BP Digital Banking Platform. Esta vista permite identificar quiénes interactúan con la solución, qué sistemas internos del banco participan y qué sistemas externos son necesarios para operar los procesos principales de banca digital.

El sistema central es la BP Digital Banking Platform, que concentra las capacidades de autenticación, consultas, transferencias, pagos, auditoría, notificaciones y onboarding biométrico. A su alrededor se muestran los actores principales, los sistemas internos del banco y las dependencias externas relevantes, como el Banco Central del Ecuador, UAFE/SISLAFT, el proveedor biométrico, el IdP corporativo y los proveedores de notificación.

Esta vista no busca detallar componentes internos; su objetivo es delimitar el alcance del sistema y dejar claro con qué actores y plataformas se relaciona.

BP Digital Banking Platform - C4 Nivel 1: Contexto

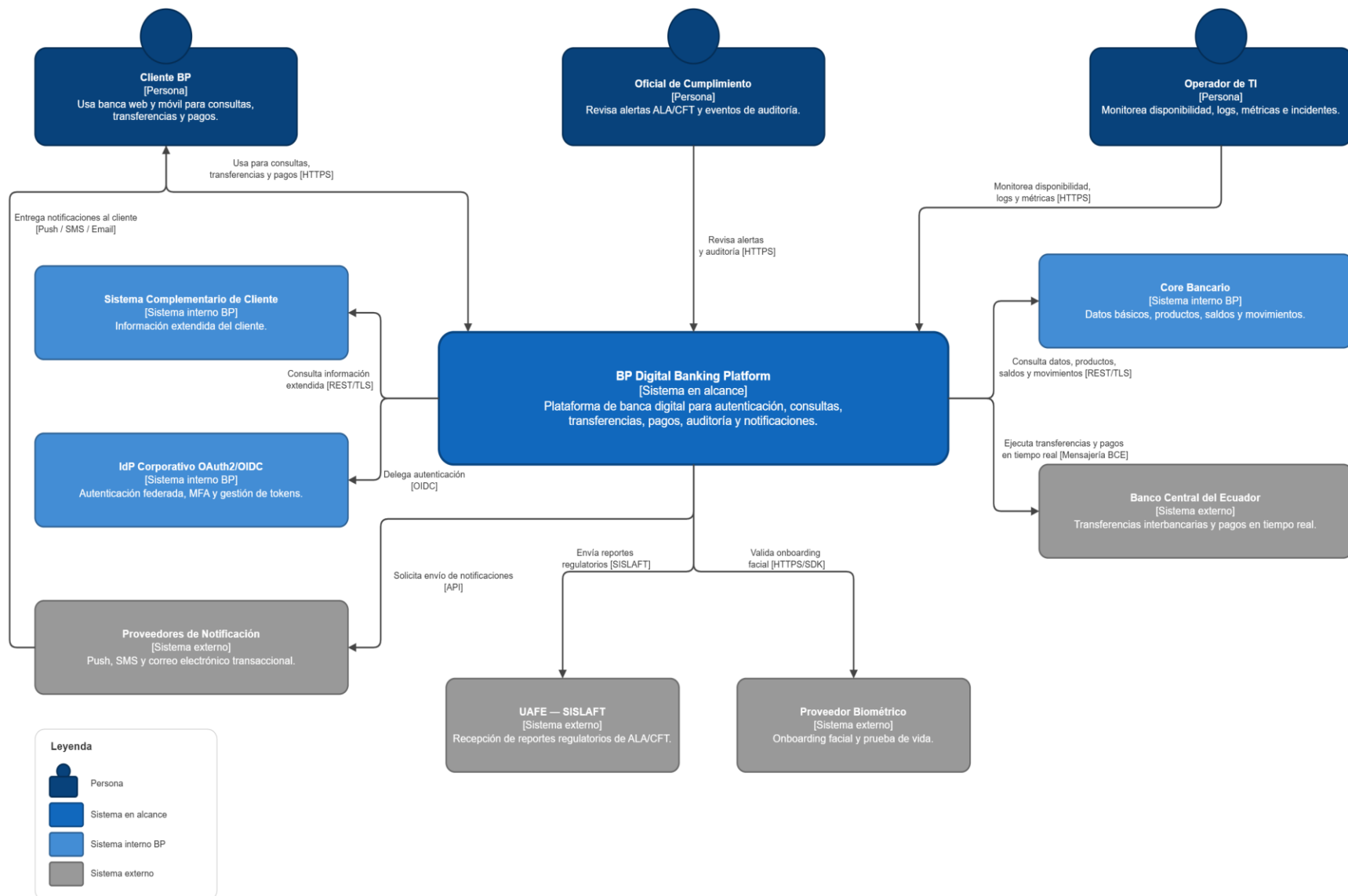


Figura 3.1 — Diagrama C4 Nivel 1: Contexto del Sistema BP Digital Banking Platform.

El sistema central en alcance es BP Digital Banking Platform, que ofrece a los clientes del banco los canales digitales web y móvil para consultas, transferencias y pagos. La plataforma no reemplaza el Core Bancario ni el sistema complementario de cliente, sino que se apoya en ellos; tampoco implementa su propio servicio de identidad, sino que delega la autenticación al IdP corporativo configurable. Las interacciones con el ecosistema regulatorio ecuatoriano (Banco Central del Ecuador y UAFE) y con los proveedores externos (biometría y notificaciones) están modeladas como integraciones externas con sus propios adaptadores.

3.1.1. Actores y sistemas identificados

La siguiente tabla describe cada elemento del diagrama y su rol dentro del contexto del sistema. La columna de tipo sigue la clasificación canónica de C4 (Persona, Sistema en alcance, Sistema interno, Sistema externo).

Elemento	Tipo	Descripción
Cliente BP	Persona	Persona natural cliente del banco. Usa la SPA Web y la App Móvil para consultar su posición consolidada, ver movimientos, realizar transferencias entre cuentas propias e interbancarias, y realizar pagos de servicios y productos financieros.
Oficial de Cumplimiento	Persona (usuario interno)	Usuario del banco responsable de supervisar las alertas ALA/CFT, validar los reportes RESU y ROS antes de su envío a UAFE, y atender requerimientos regulatorios.
Operador de TI	Persona (usuario interno)	Usuario del banco responsable del monitoreo operativo: salud de servicios, métricas, logs, trazas y atención de incidentes.
BP Digital Banking Platform	Sistema en alcance	Plataforma de banca digital web y móvil. Cubre identidad delegada, onboarding biométrico, consultas, transferencias, pagos, auditoría, notificaciones y controles transaccionales.
Core Bancario	Sistema interno BP (on-premise)	Sistema de registro autoritativo del banco. Contiene datos básicos del cliente, productos, saldos, movimientos y motor contable.
Sistema Complementario de Cliente	Sistema interno BP (on-premise)	Sistema que mantiene información extendida del cliente, requerida cuando se necesitan datos en detalle adicionales a los del Core.

IdP Corporativo OAuth2/OIDC	Producto configurable BP	Producto existente en la organización que provee autenticación federada bajo OAuth2/OIDC, emisión de tokens, MFA y gestión de sesión. La plataforma se configura como cliente del IdP, no lo construye.
Banco Central del Ecuador (BCE)	Sistema externo (regulador)	Operador del Sistema Nacional de Pagos. Provee SPI, SPL, SCI e Interoperabilidad de pagos en tiempo real (BCE-GG-008-2025) para las transferencias interbancarias y pagos en tiempo real.
UAFE — SISLAFT	Sistema externo (regulador)	Unidad de Análisis Financiero y Económico. Recibe los reportes RESU (umbral de USD 10.000), ROS y NO ROS conforme a la normativa vigente.
Proveedor Biométrico	Sistema externo (vendedor)	Proveedor especializado en reconocimiento facial y liveness detection (ISO/IEC 30107-3) para el onboarding digital. Para efectos del diseño se evalúa FacePhi como opción principal, sin cerrar la arquitectura a un proveedor específico.
Proveedores de Notificación	Sistemas externos (vendedores)	Conjunto de proveedores que entregan los canales obligatorios de notificación: Push (FCM/APNS), SMS gateway y email transaccional. Mínimo dos canales operativos en simultáneo por exigencia del enunciado y por resiliencia.

3.1.2. Relaciones y protocolos

La siguiente tabla resume cada relación del diagrama, indicando la dirección de la comunicación, el propósito de negocio y el protocolo o canal técnico de alto nivel. El detalle técnico (timeouts, autenticación entre sistemas, manejo de errores) se desarrolla en la subsección 3.2 y en el Diagrama C4 Nivel 2.

Origen	Destino	Propósito	Protocolo
Cliente BP	BP Digital Banking Platform	Consulta saldos, movimientos y ejecuta transferencias o pagos.	HTTPS
Proveedores de Notificación	Cliente BP	Entrega notificaciones transaccionales y de seguridad.	Push / SMS / Email
Oficial de Cumplimiento	BP Digital Banking Platform	Revisa alertas ALA/CFT y eventos auditados.	HTTPS
Operador de TI	BP Digital Banking Platform	Monitorea métricas, logs y trazas operativas.	HTTPS

BP Digital Banking Platform	Core Bancario	Consulta datos del cliente, productos, saldos y movimientos.	REST sobre TLS
BP Digital Banking Platform	Sistema Complementario	Consulta información extendida del cliente.	REST sobre TLS
BP Digital Banking Platform	IdP Corporativo	Delega autenticación, obtiene tokens OAuth2/OIDC.	HTTPS — OIDC
BP Digital Banking Platform	Banco Central del Ecuador	Ejecuta transferencias interbancarias y pagos en tiempo real.	Mensajería BCE
BP Digital Banking Platform	UAFA — SISLAFT	Envía reportes RESU, ROS y NO ROS.	SISLAFT
BP Digital Banking Platform	Proveedor Biométrico	Captura facial, prueba de vida y match en onboarding.	HTTPS — SDK
BP Digital Banking Platform	Proveedores de Notificación	Publica eventos de notificación al cliente.	HTTPS — APIs vendor

3.2. Contexto Técnico

Esta subsección detalla las interfaces técnicas con cada actor y sistema del diagrama de contexto. El detalle profundiza en el protocolo, la autenticación entre sistemas y los patrones de resiliencia aplicados a cada integración.

3.2.1. Interfaces con actores humanos

Las interacciones con clientes y usuarios internos van por HTTPS, con TLS 1.2 como mínimo y TLS 1.3 cuando el extremo lo soporte. Los clientes finales entran por la SPA Web (servida por CloudFront y respaldada por el BFF) o por la App Móvil en Flutter. Los usuarios internos del banco (oficiales de cumplimiento, operadores de TI) usan interfaces operativas sobre HTTPS, autenticadas contra el IdP corporativo, con autorización por roles. El monitoreo del operador de TI se hace desde consolas de CloudWatch y X-Ray, en red corporativa.

3.2.2. Interfaces con sistemas internos del banco

El Core Bancario y el Sistema Complementario son sistemas on-premise. Para llegar a ellos desde AWS uso REST sobre TLS, atravesando Direct Connect como enlace principal y VPN como respaldo. Cada integración tiene su propia capa Anti-Corruption Layer (Decisión 8) que traduce entre el modelo del sistema externo y el modelo de dominio bancario propio: esto es lo que mantiene el código del dominio limpio frente a particularidades del Core. Entre sistemas, la autenticación va por mTLS, complementada con tokens OAuth2 client_credentials cuando el servicio destino lo soporta. Cada integración tiene circuit breaker, timeouts explícitos y reintentos con backoff exponencial. La integración con el IdP corporativo es vía OIDC:

el BFF actúa como cliente confidencial y la SPA y la App como clientes públicos con PKCE, conforme a Decisión 6.

3.2.3. Interfaces con sistemas externos regulatorios

La integración con los sistemas del BCE (SPI, SPL, SCI e Interoperabilidad de pagos en tiempo real) sigue las especificaciones técnicas que publica el BCE para cada uno, con la mensajería estandarizada definida en la Resolución BCE-GG-008-2025. Cada sistema BCE tiene su propio adaptador dentro del Servicio de Transferencias, lo que aísla cambios de protocolo o de formato sin tocar el dominio. La autenticación con cada sistema sigue lo que el BCE exija. Los reportes a UAFE se envían por SISLAFT, en los formatos y plazos vigentes; RESU se genera de forma automática a partir de eventos que superan el umbral legal (USD 10.000) y ROS lo produce el Oficial de Cumplimiento sobre las alertas que eleva el motor antifraude.

3.2.4. Interfaces con proveedores externos

El proveedor biométrico se integra por HTTPS y por su SDK móvil para la captura facial y el liveness detection que corre en el dispositivo del cliente. Por ser dato biométrico, aplican controles reforzados de LOPDP: cifrado dedicado, retención limitada al ciclo de enrolamiento y nada de guardar imágenes faciales en claro después de cerrar el proceso. Los proveedores de notificación (Push, SMS, Email) se integran de forma asíncrona vía SNS/SQS y luego APIs HTTPS del proveedor. Cada canal tiene su propio adaptador y se gobierna como una fuente de fallo independiente: si el gateway de SMS se cae, los canales push y email siguen entregando, y la obligación normativa de notificar al cliente se cumple por al menos uno de los canales alternativos.

4. Estrategia de Solución

Esta sección recoge las decisiones de fondo del diseño. Es el puente entre los objetivos de calidad (sección 1), las restricciones (sección 2) y las vistas detalladas que vienen después. Las decisiones principales se resumen en la sección 9, con opciones evaluadas, justificación y riesgo principal.

4.1. Frase guía del documento

La solución propuesta no reemplaza el Core Bancario existente. Construye una capa digital segura, modular y regulatoriamente alineada, que permite operar canales web y móvil con autenticación robusta, auditoría, notificaciones, integración controlada, prevención de fraude y capacidad de evolución.

Esta frase resume tres compromisos del diseño: respetar la inversión existente del banco (el Core no se rehace), poner el foco en lo digital (canales y servicios construidos sobre el Core, no encima de él) y mantener disciplina arquitectónica (modularidad, seguridad, cumplimiento, evolución gobernada). Cualquier decisión que contradiga estos tres compromisos debería pasar por una revisión explícita.

4.2. Decisiones tecnológicas fundamentales

Las decisiones que vienen a continuación están en formato tabla por densidad, no porque sean recetas. Cada fila es el resumen de un debate cerrado: técnico, de negocio o regulatorio. El detalle resumido de las decisiones principales se desarrolla en la sección 9.

Decisión	Justificación 1 (técnica)	Justificación 2 (negocio / regulatoria)	Alternativa evaluada
Monolito modular como núcleo	Reduce complejidad operativa inicial y costo de infraestructura.	Permite separar dominios sin pagar el costo de microservicios completos.	Microservicios desde día 1 (descartado por sobredimensionamiento).
Onboarding como servicio separado	Integra biometría y vendor externo con ciclo de release distinto.	Aísla el blast radius del proveedor biométrico frente al core transaccional.	Onboarding embebido en monolito (descartado por acoplamiento).
Transferencias como servicio separado	Prevé adaptadores múltiples (SPI/SPL/SCI/Interop) con SLA propios; en MVP se priorizan los adaptadores requeridos por el alcance.	Cumplimiento de BCE-GG-008-2025 con disponibilidad 24/7 para pagos en tiempo real.	Módulo dentro del monolito (descartado por riesgo de SLA).
Notificaciones como servicio separado	Procesamiento asíncrono con tolerancia a fallos de proveedores.	Notificación obligatoria al cliente sin bloquear transacciones.	Notificación síncrona embebida (descartada por acoplamiento de latencia).

Auditoría como servicio separado	Escritura append-only de alto volumen con storage especializado.	Trazabilidad y retención conforme a Superbancos y LOPDP.	Auditoría en la BD transaccional (descartada por contención).
Antifraude transversal en el monolito	Componente reutilizable por login, transferencias, pagos y onboarding.	Permite actualización de reglas sin redeploy del monolito (hot-reload).	Servicio independiente desde día 1 (postergado hasta reutilización real).
AWS ECS Fargate	Serverless containers; sin gestión de nodos.	TCO menor que EKS para el volumen estimado del MVP.	AWS EKS (Kubernetes); descartado por costo operativo y SRE.
AWS SQS + SNS	Mensajería gestionada que reduce la carga operativa y elimina la administración de un broker propio.	Integración nativa con el ecosistema AWS y modelo de pago por uso alineado con FinOps.	RabbitMQ/Kafka autohospedado (descartado por TCO operativo).
BFF para SPA Web	Evita almacenar tokens en el navegador.	Recomendado por IETF para aplicaciones de banca y datos personales.	SPA con tokens en localStorage (descartado por riesgo XSS).
OAuth2 Authorization Code + PKCE	Estándar OAuth 2.1; flujo recomendado para SPA y móvil.	Mitiga interceptación del código de autorización en clientes públicos.	Implicit Flow (deprecado), Resource Owner Password (no recomendado).

4.2.1. Comparativa Frontend: SPA Web y App Móvil

El enunciado solicita explícitamente que la elección de framework multiplataforma para la aplicación móvil se haga mencionando al menos dos opciones evaluadas y justificando la selección. La misma exigencia se aplica, por coherencia, a la SPA Web. Las dos comparativas se presentan a continuación.

SPA Web — React + TypeScript vs Angular

Criterio	React + TypeScript (elegido)	Angular (alternativa evaluada)
Naturaleza	Librería UI con ecosistema abierto.	Framework opinionado completo (CLI, DI, RxJS, módulos).
Curva de aprendizaje	Menor; flexibilidad para incorporar nuevos integrantes.	Mayor; requiere familiaridad con el framework completo.
Tipado	TypeScript opcional pero adoptado como estándar del proyecto.	TypeScript nativo y obligatorio.
Tamaño de bundle inicial	Generalmente menor con tree-shaking.	Mayor por inclusión del framework completo.

Integración con BFF y SSR	Excelente (Next.js, Remix).	Soportada (Angular Universal).
Idoneidad para banca	Adecuada; usado por bancos en LATAM.	Adecuada; usado por bancos grandes con equipos numerosos.
Justificación de elección	Productividad, ecosistema maduro, menor curva, facilidad de integración con design systems.	Defendible para organizaciones con gobierno técnico prescriptivo y equipos grandes; no es el caso del MVP.

La selección final es React + TypeScript. No se afirma que sea estándar bancario único; ambas opciones son defendibles y la decisión se basa en simplicidad operativa, tiempo de desarrollo del MVP y compatibilidad natural con el patrón BFF.

App móvil — Flutter vs React Native

Criterio	Flutter (elegido)	React Native (alternativa evaluada)
Lenguaje	Dart.	JavaScript / TypeScript.
Motor de renderizado	Skia propio (consistencia visual entre plataformas).	Componentes nativos del sistema.
Rendimiento en UI compleja	Alto; ideal para flujos con animaciones y biometría.	Bueno; dependiente del bridge nativo.
Integración con SDK biométrico	Soportada por los principales proveedores del mercado.	Soportada con módulos nativos adicionales.
Madurez en banca LATAM	Alta; varios bancos de la región lo usan en producción.	Alta; ampliamente adoptado en fintech.
Justificación de elección	Rendimiento consistente, una sola base de código, ecosistema estable, integración natural con módulos nativos para biometría y seguridad.	Defendible si el equipo es JavaScript-native y se requiere reutilización con la SPA Web.

La selección final es Flutter por la consistencia visual entre iOS y Android, la robustez del motor de renderizado y la disponibilidad de SDKs biométricos maduros para el flujo de onboarding y autenticación local del dispositivo.

4.2.2. Flujo de autenticación OAuth 2.0 recomendado

El enunciado requiere recomendar el mejor flujo de autenticación del estándar OAuth 2.0. El estándar define varios flujos (grants), cada uno orientado a un tipo de cliente y nivel de confianza. La elección debe responder al tipo de aplicación (cliente público vs confidencial) y a las garantías de seguridad esperadas.

Flujos del estándar evaluados:

- Authorization Code (con PKCE) — recomendado para clientes públicos como SPA y aplicaciones móviles nativas.
- Authorization Code (sin PKCE) — válido históricamente para clientes confidenciales; insuficiente sin PKCE en clientes públicos modernos.
- Implicit Flow — deprecado por OAuth 2.1 y por el IETF; expone tokens al navegador.
- Resource Owner Password Credentials (ROPC) — no recomendado para aplicaciones de usuario final; entrega la contraseña al cliente.
- Client Credentials — destinado a comunicación máquina-a-máquina, no a autenticación de usuario.
- Device Code — destinado a dispositivos sin teclado o navegador (TVs, IoT); no aplica al caso.

Recomendación: Authorization Code Flow con PKCE (Proof Key for Code Exchange) tanto para la SPA Web como para la App Móvil. Las dos justificaciones técnicas son:

- La principal razón es que PKCE mitiga el ataque de interceptación del código de autorización en clientes públicos, justo donde el client secret no se puede proteger bien (navegador o app nativa).
- A esto se suma que Authorization Code con PKCE es el flujo recomendado por OAuth 2.1 y por la guía OAuth 2.0 for Browser-Based Apps del IETF para aplicaciones que manejan datos personales y financieros. No hay otro flujo del estándar que encaje mejor con un caso bancario.

Refinamiento por canal: en la SPA Web se complementa con el patrón Backend-For-Frontend (BFF), que evita almacenar tokens en el navegador y mantiene la sesión con el cliente mediante cookies HttpOnly/Secure/SameSite=strict. En la App Móvil se aplica la guía RFC 8252 (OAuth 2.0 for Native Apps): autorización vía navegador externo del sistema (no WebView embebida) y almacenamiento de tokens en Keychain (iOS) o Keystore (Android).

4.2.3. Patrón de diseño para clientes frecuentes: Cache-Aside

El enunciado solicita una alternativa basada en patrones de diseño para el mecanismo de persistencia destinado a clientes frecuentes, indicando los componentes que deben interactuar. La propuesta es el patrón Cache-Aside (también conocido como Lazy Loading), por su simplicidad, su robustez y su adecuación al perfil de lectura intensiva característico de la posición consolidada y los movimientos recientes.

Componentes que interactúan y flujo del patrón:

- Aplicación cliente (SPA / App móvil) emite la consulta hacia el backend.
- Módulo de Movimientos / Posición Consolidada recibe la solicitud y delega en su Repository.
- Repository consulta primero la caché (Amazon ElastiCache for Redis) usando una clave compuesta por identificador del cliente y tipo de dato.
- Si la caché responde (cache hit): se entrega el resultado al cliente.
- Si la caché no responde (cache miss): el Repository consulta el Core Bancario a través del Anti-Corruption Layer, escribe el resultado en la caché con un TTL definido (por ejemplo, 60 segundos para saldos, 5 minutos para movimientos) y entrega el dato al cliente.
- La invalidación se produce por TTL natural o por eventos de cambio (por ejemplo, una transferencia ejecutada publica un evento que invalida la clave correspondiente).

Justificaciones teóricas:

- Lo primero es que Cache-Aside desacopla la caché del sistema de registro autoritativo (el Core). Si la caché falla, la disponibilidad no se cae: el Repository va contra el Core. La caché es capa de aceleración, no fuente de verdad.
- Lo segundo, y para mí lo más importante en este caso, es que reduce la carga sobre el Core Bancario y baja la latencia percibida por el cliente en las consultas frecuentes (saldos, últimos movimientos). Y todo eso sin pedirle cambios al Core, que es lo que el ejercicio impone.

Alternativas evaluadas y descartadas: Read-Through y Write-Through requieren que la caché entienda el modelo de datos del Core (acoplamiento). Write-Behind introduce riesgo de pérdida de escrituras y no aplica a un escenario donde el Core es el sistema de registro. Refresh-Ahead es adecuado para datos predecibles, pero agrega complejidad operativa innecesaria en el MVP.

4.3. Descomposición de alto nivel

La plataforma se organiza en diez dominios funcionales. La separación es lógica y se materializa parcialmente como módulos del monolito y parcialmente como servicios separados según la decisión de la sección 4.2.

4.3.1. Canales Digitales

- SPA Web (React + TypeScript) servida vía CloudFront.
- App Móvil (Flutter) para iOS y Android.

4.3.2. Identidad y Seguridad

- OAuth2/OIDC sobre producto corporativo configurable.
- Authorization Code + PKCE como flujo único para SPA y App Móvil.

- MFA y step-up authentication para operaciones sensibles.
- Recuperación de usuario y contraseña con respuestas anti-enumeration.
- Bloqueo y desbloqueo seguro con backoff progresivo.
- Gestión de dispositivos confiables.
- Revocación de sesiones y tokens.

Métodos de autenticación post-onboarding:

A partir del onboarding biométrico, el usuario puede ingresar al sistema mediante los siguientes métodos. La política de qué método se admite por operación se gobierna por el motor de step-up authentication según el nivel de riesgo y el monto de la transacción.

- Usuario + contraseña: método base, gobernado por política de complejidad y caducidad, con respuestas anti-enumeration en recuperación.
- Biometría local del dispositivo: huella dactilar (Touch ID, Android Fingerprint) o reconocimiento facial del sistema operativo (Face ID, BiometricPrompt). La biometría se valida localmente en el enclave seguro del dispositivo; el sistema solo recibe la confirmación de éxito, nunca la plantilla biométrica.
- OTP de un solo uso: enviado por SMS o email para step-up authentication en operaciones sensibles o desde dispositivos no confiables.
- Push authentication: notificación de aprobación enviada a un dispositivo previamente registrado y confiable, con confirmación dentro de la app.

4.3.3. Onboarding Biométrico

- Consentimiento informado bajo LOPDP.
- Captura de datos mínimos del cliente.
- Reconocimiento facial.
- Prueba de vida (liveness detection, ISO 30107-3).
- Enrolamiento digital y emisión de credenciales iniciales.

4.3.4. Perfil y Posición Consolidada

- Datos básicos del cliente.
- Productos contratados (cuentas, tarjetas, créditos).
- Saldos disponibles y contables.
- Alertas relevantes.

4.3.5. Movimientos y Estados de Cuenta

- Últimos movimientos.
- Histórico ampliado.
- Descarga PDF/CSV.
- Caché optimizado para clientes frecuentes (patrón Cache-Aside).

4.3.6. Transferencias y Pagos

- Transferencias entre cuentas propias.
- Transferencias a terceros dentro de BP.
- Transferencias interbancarias vía sistemas BCE.
- Pagos en tiempo real conforme a interoperabilidad BCE.
- Pagos de servicios.
- Pagos de tarjetas y préstamos propios.
- Beneficiarios frecuentes.

4.3.7. Riesgo, Límites y Cumplimiento

- Cupos por canal (web, móvil, QR/llaves).
- Límites diarios, mensuales y por destinatario.
- Motor antifraude transaccional.
- Controles ALA/CFT.
- Generación de eventos para reportes UAFE (RESU y ROS).

4.3.8. Notificaciones

- Push (FCM / APNS).
- Email transaccional (AWS SES).
- SMS (gateway externo).

4.3.9. Auditoría

- Acciones del cliente.
- Eventos de seguridad.
- Eventos transaccionales.
- Retención y trazabilidad conforme a Superbancos y LOPDP.

4.3.10. Integración

La capa de integración expone los servicios de negocio a través del API Gateway y los conecta con los sistemas externos mediante adaptadores. El enunciado declara explícitamente tres servicios principales que deben existir; la arquitectura los incluye y agrega los servicios adicionales necesarios para atender las exigencias del MVP (onboarding biométrico, notificaciones, auditoría y antifraude).

Servicios mínimos exigidos por el enunciado:

- Servicio de consulta de datos básicos del cliente.
- Servicio de consulta de movimientos.
- Servicio de transferencias (incluye llamadas a servicios externos según el tipo de transferencia).

Servicios adicionales propuestos por la arquitectura:

- Servicio de Posición Consolidada — agrega productos, saldos y alertas en una sola respuesta optimizada para la pantalla inicial.
- Servicio de Pagos — gestiona pagos de servicios, tarjetas y préstamos propios, separados conceptualmente de las transferencias.
- Servicio de Beneficiarios y Cupos — administra la lista de beneficiarios frecuentes y los límites por canal.
- Servicio de Onboarding Biométrico — extraído para aislar el ciclo de vida del proveedor biométrico.
- Servicio de Notificaciones — extraído para procesamiento asíncrono multicanal.
- Servicio de Auditoría — extraído para escritura append-only de alto volumen.
- Motor Antifraude — componente transversal del monolito, consumido por login, transferencias, pagos y onboarding.

Sistemas externos integrados:

- Core Bancario (REST con Anti-Corruption Layer).
- Sistema complementario de cliente (REST con Anti-Corruption Layer).
- Sistemas del Banco Central del Ecuador (adaptadores SPI, SPL, SCI e interoperabilidad).
- Proveedor biométrico (REST + SDK móvil).
- Proveedores de notificación (SES, SNS, gateway SMS, FCM, APNS).
- UAFAE (SISLAFT) para envío de RESU y ROS.

4.4. Cómo se atienden los objetivos de calidad

La siguiente tabla resume cómo la estrategia de solución atiende cada objetivo de calidad declarado en la sección 1.2.

Objetivo de calidad	Cómo lo atiende la arquitectura
Seguridad	OAuth2 + PKCE; BFF; MFA y step-up; cifrado en tránsito (TLS 1.2 mínimo, TLS 1.3 preferente) y reposo (KMS); WAF y Shield en perímetro; segregación de redes; principio de mínimo privilegio.
Disponibilidad	Multi-AZ en sa-east-1; auto-healing nativo de ECS Fargate; circuit breakers en integraciones externas; DR activo-pasivo en us-east-1.
Cumplimiento normativo	Diseño guiado por LOPDP, Superbancos, UAFE y BCE; generación de eventos para reportes; retención auditada.
Trazabilidad	Servicio de Auditoría append-only; correlation IDs en todas las trazas; logs centralizados en CloudWatch.
Tolerancia a fallos	Asincronía vía SQS/SNS; reintentos con backoff exponencial; dead-letter queues; degradación graceful.
Mantenibilidad	Monolito modular con fronteras claras; ACL para sistemas externos; CI/CD con pipelines independientes por servicio extraído.
Costo operativo	Servicios gestionados (Fargate, SQS, RDS, SES); sin clusters propios; auto-scaling por demanda.
Rendimiento	Caché para datos de lectura frecuente; CDN para activos estáticos; índices en BD; conexiones persistentes a Core vía pool gestionado.

5. Vista de Bloques de Construcción

Esta sección describe la estructura estática de la BP Digital Banking Platform, desde una vista general de contenedores hasta el detalle de los componentes más relevantes. El objetivo es mostrar cómo se separan las responsabilidades principales del sistema y cómo se conectan los canales digitales, los servicios internos, las bases de datos, la mensajería y los sistemas externos.

5.1. Whitebox del sistema completo (C4 Nivel 2 — Contenedores)

El diagrama C4 Nivel 2 muestra los contenedores principales de la BP Digital Banking Platform. En esta vista se identifican los canales de acceso, los componentes de borde, el backend digital, los servicios separados por responsabilidad, las piezas de datos y mensajería, y las integraciones con sistemas internos y externos.

La decisión central es mantener un Core Digital Backend como monolito modular para las capacidades comunes de banca digital, separando solo los servicios que tienen razones claras de autonomía: Transferencias, Onboarding Biométrico, Notificaciones y Auditoría. Esta separación permite controlar costos y complejidad, sin perder trazabilidad ni capacidad de evolución.

BP Digital Banking Platform - C4 Nivel 2: Contenedores

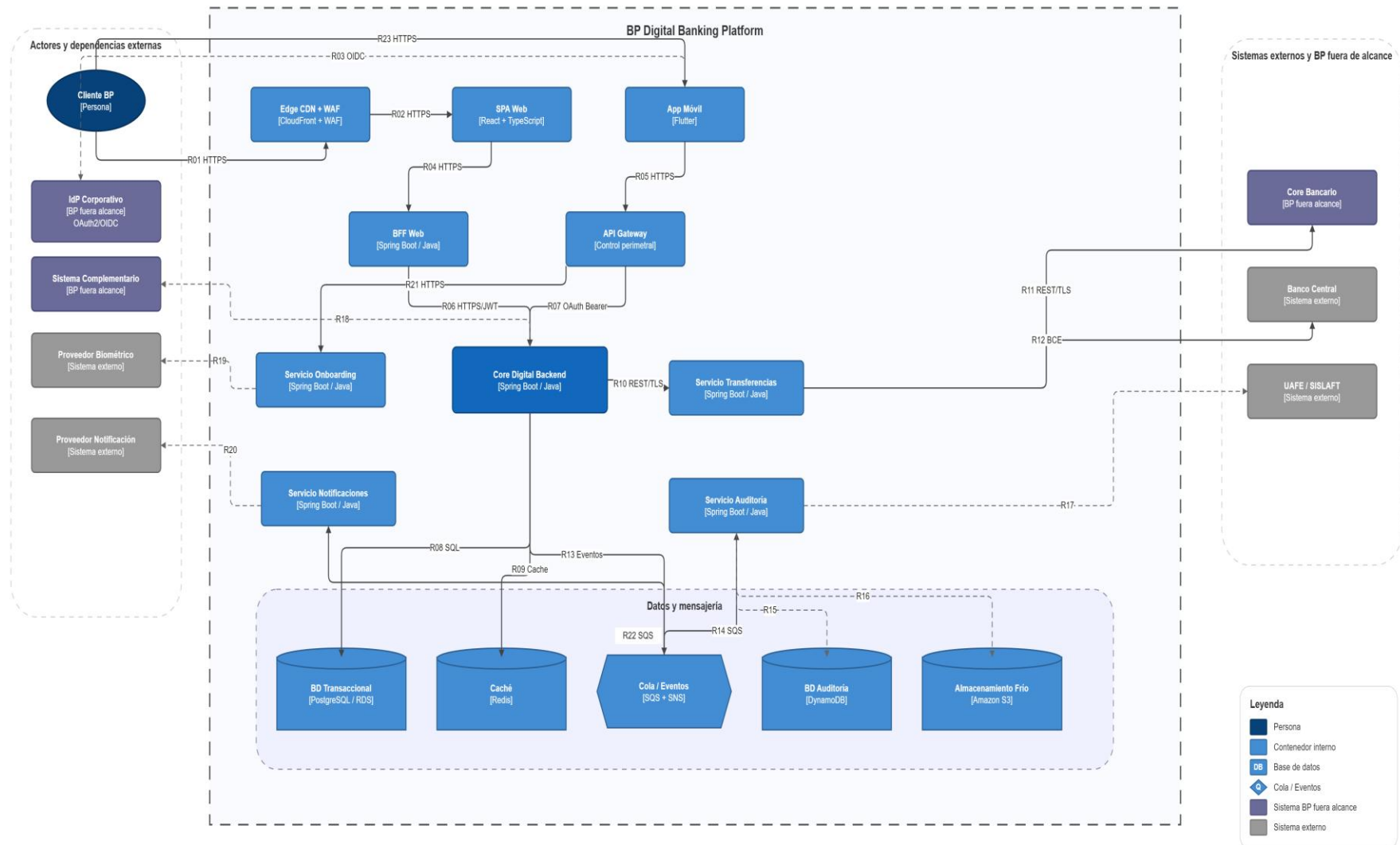


Figura 5.1 — Diagrama C4 Nivel 2: Contenedores de la BP Digital Banking Platform.

Tabla 5.1.1 — Contenedores de la BP Digital Banking Platform

Contenedor	Tipo	Tecnología	Responsabilidad	Razón de existir
Ciente BP	Persona	No aplica	Usuario de banca web y móvil.	Representa el actor principal que consulta productos, realiza pagos y ejecuta transferencias.
Edge CDN + WAF	Infraestructura perimetral	AWS CloudFront + WAF + Shield	Entrada segura de tráfico web y móvil.	Proteger el borde, distribuir contenido y reducir exposición directa.
SPA Web	Contenedor interno	React 18 + TypeScript	Interfaz web para clientes.	Separar experiencia web del backend interno.
App Móvil	Contenedor interno	Flutter	Aplicación móvil iOS/Android.	Proveer acceso móvil multiplataforma.
BFF Web	Contenedor interno	Spring Boot 3 / Java 21	Backend especializado para la SPA web.	Adaptar APIs para canal web y manejar sesión segura sin exponer tokens al navegador.
API Gateway	Contenedor interno	API Gateway / control perimetral	Publicación de APIs seguras y enrutamiento.	Centralizar validación y direccionamiento de APIs.
Core Digital Backend	Contenedor interno	Spring Boot 3 / Java 21	Monolito modular: clientes, cuentas, pagos, beneficios, antifraude.	Concentrar capacidades centrales sin dividir módulos internos como contenedores.
Servicio Onboarding	Contenedor interno	Spring Boot 3 / Java 21	Registro digital y validación de identidad.	Aislar flujo sensible que integra biometría, consentimiento y enrolamiento.
Servicio Transferencias	Contenedor interno	Spring Boot 3 / Java 21	Transferencias propias, terceros BP e interbancarias; pagos en tiempo real BCE.	Separar lógica transaccional crítica y sus integraciones bancarias.
Servicio Notificaciones	Contenedor interno	Spring Boot 3 / Java 21	Notificaciones multicanal.	Desacoplar envío de mensajes de flujos transaccionales.
Servicio Auditoría	Contenedor interno	Spring Boot 3 / Java 21	Eventos auditables y evidencia regulatoria.	Mantener trazabilidad y soporte regulatorio sin mezclar con lógica de negocio.
BD Transaccional	Base de datos	PostgreSQL / AWS RDS Multi-AZ	Datos operativos de la plataforma digital.	Persistir información operativa con consistencia relacional.
Caché	Base de datos / caché	Redis / AWS ElastiCache	Sesiones, datos frecuentes y caché.	Reducir latencia y carga sobre fuentes transaccionales.
Cola/Eventos	Mensajería	AWS SQS + SNS	Mensajería asíncrona para auditoría y notificaciones.	Desacoplar productores y consumidores.
BD Auditoría	Base de datos	Amazon DynamoDB	Auditoría append-only de eventos críticos.	Registrar eventos auditables con escritura rápida y trazabilidad.
Almacenamiento Frío	Almacenamiento	Amazon S3	Evidencia, archivos y retención.	Conservar documentos e históricos de forma durable.
IdP Corporativo	Sistema BP fuera de alcance	OAuth2/OIDC	Autenticación corporativa BP.	Delegar autenticación, MFA y gestión de identidad.
Sistema Complementario	Sistema BP fuera de alcance	Sistema interno BP on-premise	Información extendida del cliente.	Consultar atributos de cliente no residentes en el backend digital.
Core Bancario	Sistema BP fuera de alcance	Sistema interno BP on-premise	Productos, saldos, movimientos y contabilidad.	Integrar plataforma digital con registros bancarios principales.
Proveedor Biométrico	Sistema externo	Vendor biométrico	Validación facial y prueba de vida.	Soportar validación de identidad durante el onboarding digital.
Banco Central	Sistema externo / regulador	Mensajería BCE	Transferencias interbancarias y pagos en tiempo real.	Ejecutar operaciones interbancarias mediante sistema regulado.
Proveedor de Notificación	Sistema externo	API de mensajería	Push, SMS y correo transaccional.	Entregar comunicaciones transaccionales por canales externos.
UAFA / SISLAFT	Sistema externo / regulador	SISLAFT	Recepción de información regulatoria.	Permitir envío o preparación de reportes regulatorios ALA/CFT.

Tabla 5.1.2 — Relaciones del C4 Nivel 2 (versión compacta)

ID	Origen	Destino	Propósito	Protocolo	Criticidad
R01	Cliente BP	Edge CDN + WAF	Acceder a banca web y móvil mediante el punto de entrada protegido.	HTTPS	Alta
R02	Edge CDN + WAF	SPA Web	Entregar la aplicación web al navegador del cliente.	HTTPS	Media
R03	App Móvil	IdP Corporativo	Autenticar al usuario móvil mediante identidad corporativa.	OAuth2/OIDC	Alta
R04	SPA Web	BFF Web	Consumir backend especializado para la experiencia web.	HTTPS	Alta
R05	App Móvil	API Gateway	Invocar APIs protegidas del canal digital.	HTTPS	Alta
R06	BFF Web	Core Digital Backend	Enviar solicitudes web autenticadas al Core Digital Backend.	HTTPS/JWT	Alta
R07	API Gateway	Core Digital Backend	Enrutar APIs transaccionales hacia el backend principal.	HTTPS + OAuth Bearer	Alta
R08	Core Digital Backend	BD Transaccional	Persistir datos operativos de la plataforma digital.	SQL/JDBC/TLS	Alta
R09	Core Digital Backend	Caché	Consultar sesiones y datos frecuentes.	RESP/TLS	Media
R10	Core Digital Backend	Servicio Transferencias	Delegar ejecución especializada de transferencias y pagos.	REST/TLS + OAuth Bearer	Alta
R11	Servicio Transferencias	Core Bancario	Ejecutar operaciones bancarias contra sistemas BP.	REST/TLS + Direct Connect	Crítica
R12	Servicio Transferencias	Banco Central	Ejecutar pagos interbancarios y operaciones en tiempo real.	Mensajería BCE	Crítica
R13	Core Digital Backend	Cola/Eventos	Publicar eventos de negocio para procesamiento asíncrono.	AWS SDK	Alta
R14	Cola/Eventos	Servicio Auditoría	Entregar eventos auditables al servicio de auditoría.	SQS	Alta
R15	Servicio Auditoría	BD Auditoría	Registrar eventos críticos con modelo append-only.	AWS SDK	Alta
R16	Servicio Auditoría	Almacenamiento Frío	Archivar evidencia y retención histórica.	AWS SDK	Media
R17	Servicio Auditoría	UAFE / SISLAFT	Preparar y remitir información regulatoria cuando corresponda.	SISLAFT	Alta
R18	Core Digital Backend	Sistema Complementario	Consultar información extendida del cliente.	REST/TLS	Media
R19	Servicio Onboarding	Proveedor Biométrico	Validar identidad, rostro y prueba de vida.	HTTPS/SDK	Alta
R20	Servicio Notificaciones	Proveedor de Notificación	Enviar mensajes transaccionales multicanal.	HTTPS/API	Media
R21	API Gateway	Servicio Onboarding	Enrutar solicitudes de onboarding hacia el servicio especializado.	HTTPS	Alta
R22	Cola/Eventos	Servicio Notificaciones	Entregar eventos para notificación multicanal.	SQS	Media
R23	Cliente BP	App Móvil	Uso de la aplicación móvil por parte del cliente.	HTTPS	Alta

El detalle completo de relaciones de este diagrama se conserva como material complementario versionado en el repositorio.

5.2. Nivel de componentes (C4 Nivel 3)

Para el C4 Nivel 3 se detallan únicamente los contenedores con mayor complejidad interna e impacto arquitectónico: Core Digital Backend, Servicio de Transferencias y Servicio de Onboarding Biométrico. No se desarrolla una vista de componentes para todos los contenedores del C4 Nivel 2, porque algunos cumplen funciones de infraestructura o soporte, como base de datos, caché, mensajería o almacenamiento.

Esta selección mantiene el documento enfocado en los módulos donde existen decisiones relevantes de diseño, seguridad, integración, cumplimiento y resiliencia.

BP Digital Banking Platform - C4 Nivel 3-A: Componentes del Core Digital Backend

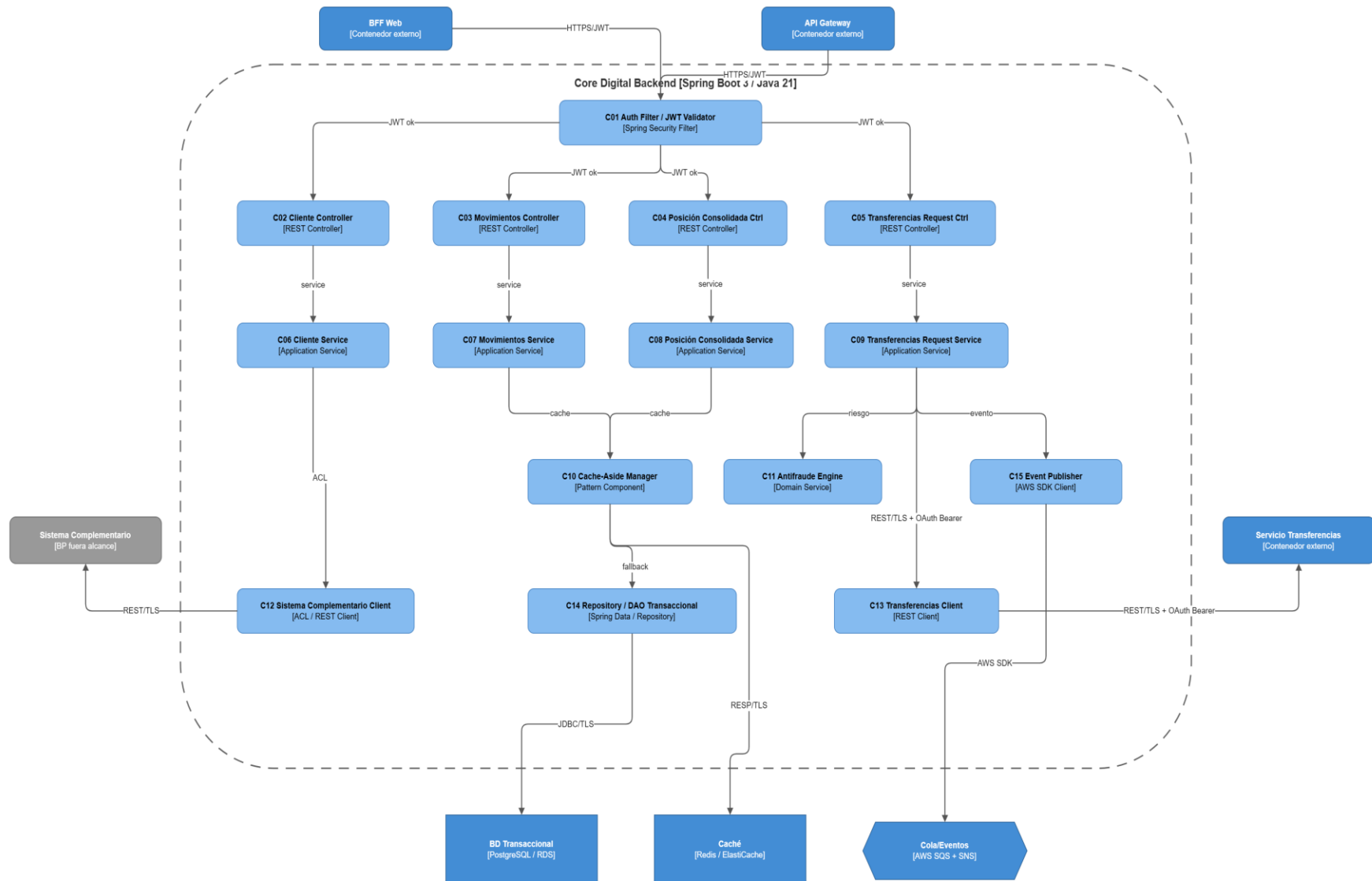


Figura 5.2 — Diagrama C4 Nivel 3-A: Componentes del Core Digital Backend.

Tabla 5.2.1 — Componentes del Core Digital Backend

ID	Componente	Tipo	Responsabilidad	Patrón / decisión	Justificación
C01	Auth Filter / JWT Validator	Spring Security Filter	Valida JWT, claims, scopes y canal antes de llegar a controllers.	Filter Chain	Centraliza seguridad técnica y evita duplicar validaciones por endpoint.
C02	Cliente Controller	REST Controller	Expone datos básicos y perfil del cliente.	Controller	Separa contrato HTTP de la lógica de aplicación.
C03	Movimientos Controller	REST Controller	Expone histórico de movimientos.	Controller	Aísla la API de movimientos del procesamiento interno.
C04	Posición Consolidada Controller	REST Controller	Expone productos, saldos y resumen consolidado.	Controller	Entrega una API estable para la vista inicial del canal digital.
C05	Transferencias Request Controller	REST Controller	Recibe solicitudes de pagos/transferencias y las deriva.	Controller	Evita que la capa HTTP ejecute reglas transaccionales.
C06	Cliente Service	Application Service	Orquesta datos básicos y extendidos del cliente.	Application Service	Coordina reglas de aplicación e integración con Sistema Complementario.
C07	Movimientos Service	Application Service	Consulta, normaliza y cachea movimientos.	Application Service	Encapsula lógica de consulta y normalización.
C08	Posición Consolidada Service	Application Service	Consolida productos, saldos y cuentas.	Application Service	Construye una respuesta agregada sin exponer fuentes internas.
C09	Transferencias Request Service	Application Service	Valida solicitud, aplica límites/antifraude y delega al Servicio Transferencias.	Orchestration	Ejecuta validaciones del Core antes de llamar al contenedor transaccional.
C10	Cache-Aside Manager	Pattern Component	Aplica patrón Cache-Aside con Redis para consultas frecuentes.	Cache-Aside	Reutiliza lógica de caché y mantiene fallback a la fuente autoritativa.
C11	Antifraude Engine	Domain Service	Evalúa reglas de riesgo por canal, monto y comportamiento.	Rules Engine	Permanece en el Core para evitar dependencias circulares.
C12	Sistema Complementario Client	ACL / REST Client	Consulta información extendida del cliente.	Anti-Corruption Layer	Protege el dominio interno frente al contrato del sistema externo.
C13	Transferencias Client	REST Client	Delega operaciones al contenedor Servicio Transferencias.	Client Adapter	Mantiene una única salida controlada hacia transferencias.
C14	Repository / DAO Transaccional	Spring Data / Repository	Acceso a BD Transaccional.	Repository	Encapsula persistencia relacional y consultas operativas.
C15	Event Publisher	AWS SDK Client	Publica eventos hacia Cola/Eventos.	Publisher / Domain Events	Desacopla auditoría, notificaciones y procesamiento asíncrono.

El detalle completo de relaciones de este diagrama se conserva como material complementario versionado en el repositorio.

BP Digital Banking Platform - C4 Nivel 3-B: Componentes del Servicio Transferencias

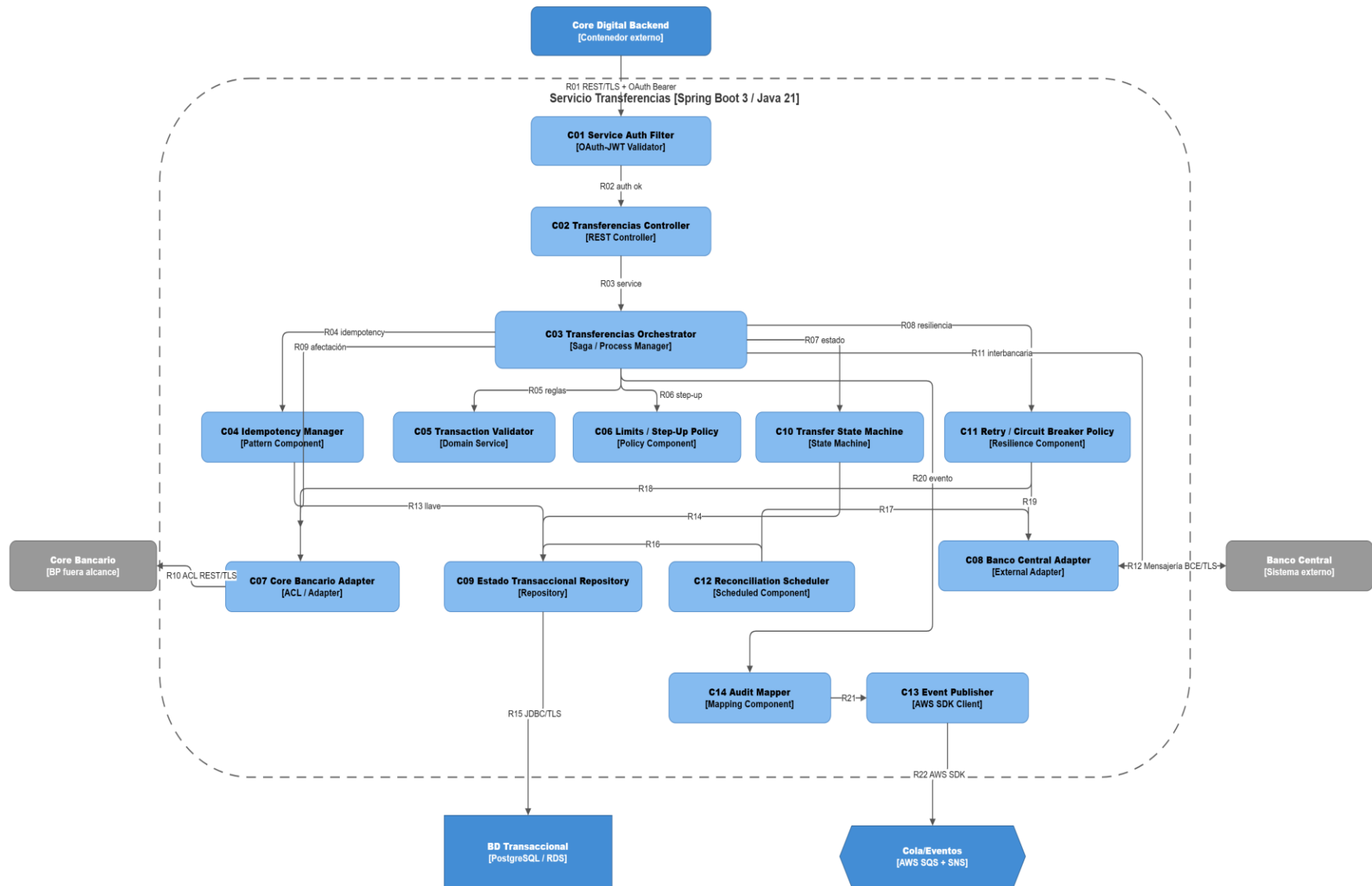


Figura 5.3 — Diagrama C4 Nivel 3-B: Componentes del Servicio de Transferencias.

Tabla 5.3.1 — Componentes del Servicio Transferencias

ID	Componente	Tipo	Responsabilidad	Patrón / decisión	Justificación
C01	Service Auth Filter / OAuth-JWT Validator	Security Filter	Valida comunicación desde Core Digital Backend mediante OAuth bearer.	Filter Chain / OAuth bearer	Protege el contenedor frente a invocaciones no autorizadas.
C02	Transferencias Controller	REST Controller	Recibe solicitudes internas de transferencias y pagos.	Controller	Separa contrato de entrada de la orquestación transaccional.
C03	Transferencias Orchestrator	Process Manager / Saga	Coordina validaciones, afectación bancaria, integración BCE y publicación de eventos.	Saga / Process Manager	Controla el flujo transaccional y evita lógica dispersa.
C04	Idempotency Manager	Pattern Component	Evita duplicidad de operaciones por reintentos, doble clic o timeouts.	Idempotency Key	Reduce riesgo de doble afectación financiera.
C05	Transaction Validator	Domain Service	Valida cuenta origen/destino, monto, moneda y reglas operativas.	Domain Validation	Centraliza reglas transaccionales antes de ejecutar la operación.
C06	Limits / Step-Up Policy	Policy Component	Evalúa límites, montos sensibles y necesidad de autenticación reforzada.	Policy	Permite decisiones de seguridad transaccional por monto/canal.
C07	Core Bancario Adapter	ACL / Adapter	Integra afectación contable, saldos y movimientos con Core Bancario.	Anti-Corruption Layer	Aísla el contrato bancario on-premise del dominio del servicio.
C08	Banco Central Adapter	External Adapter	Integra transferencias interbancarias y pagos con Banco Central.	External Adapter	Encapsula mensajería BCE y manejo de respuestas externas.
C09	Estado Transaccional Repository	Repository	Registra órdenes, estados, referencias e idempotencia.	Repository	Mantiene persistencia transaccional y trazabilidad operativa.
C10	Transfer State Machine	State Machine	Controla estados: PENDIENTE, VALIDADA, ENVIADA, CONFIRMADA, RECHAZADA, REVERSADA.	State Machine	Hace explícito el ciclo de vida de la operación.
C11	Retry / Circuit Breaker Policy	Resilience Component	Aplica timeouts, reintentos controlados y circuit breaker.	Retry / Circuit Breaker	Evita fallos en cascada y llamadas indefinidas a externos.
C12	Reconciliation Scheduler	Scheduled Component	Reconcilia operaciones pendientes, inciertas o sin confirmación.	Scheduled Reconciliation	Reduce riesgo operativo por estados indeterminados.
C13	Event Publisher	AWS SDK Client	Publica eventos transaccionales hacia Cola/Eventos.	Publisher / Domain Events	Desacopla auditoría y notificaciones del flujo transaccional.
C14	Audit Mapper	Mapping Component	Normaliza eventos, correlación, usuario, canal y evidencia mínima antes de publicar.	Event Mapping	Asegura consistencia de trazabilidad para auditoría posterior.

El detalle completo de relaciones de este diagrama se conserva como material complementario versionado en el repositorio.

BP Digital Banking Platform - C4 Nivel 3-C: Componentes del Servicio Onboarding Biométrico

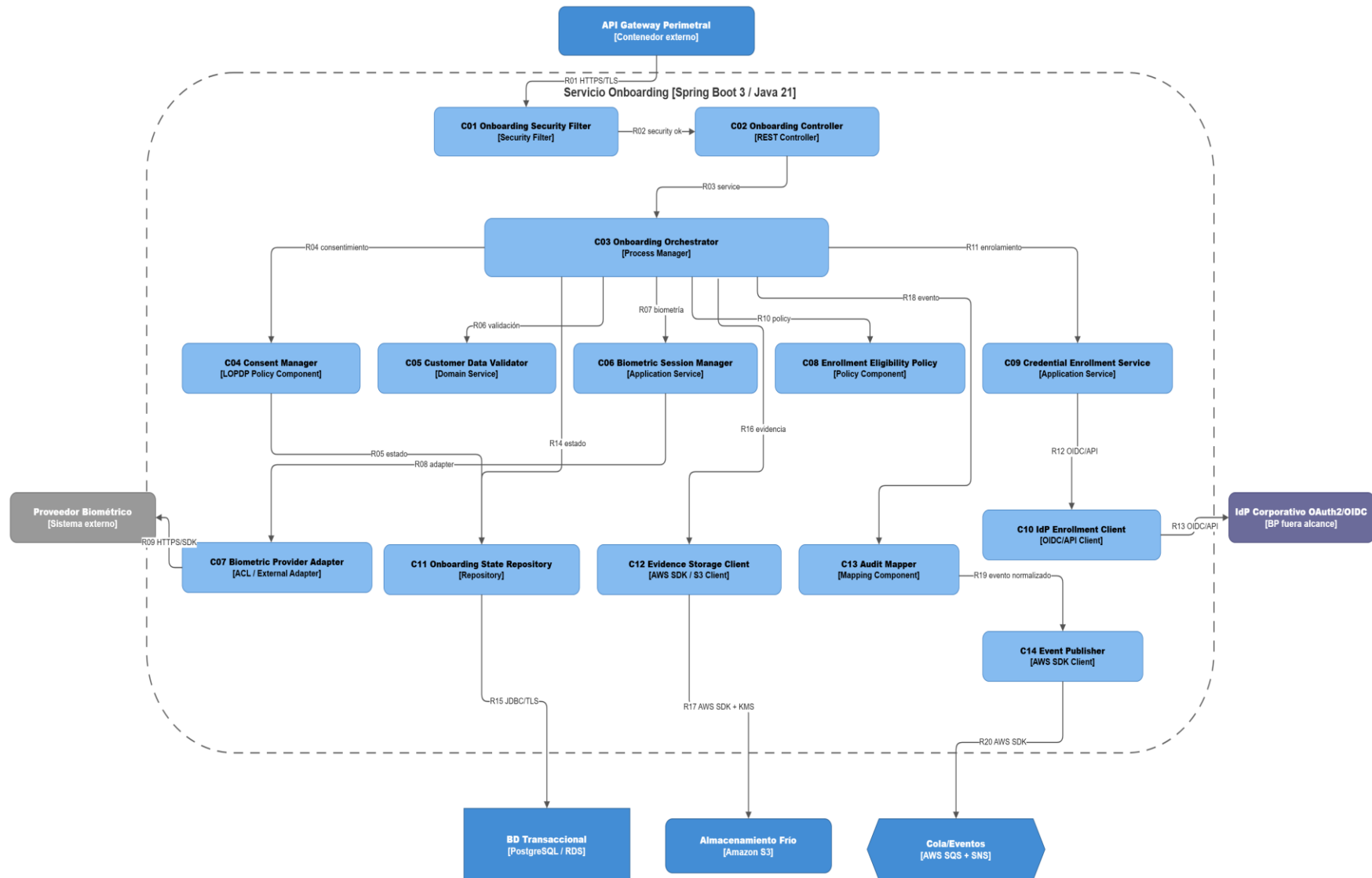


Figura 5.4 — Diagrama C4 Nivel 3-C: Componentes del Servicio de Onboarding Biométrico.

Tabla 5.4.1 — Componentes del Servicio Onboarding Biométrico

ID	Componente	Tipo	Responsabilidad	Patrón / decisión	Justificación
C01	Onboarding Security Filter	Security Filter	Valida canal, token técnico o sesión temporal, rate limit y controles anti-abuso.	Filter Chain	El onboarding puede iniciar antes de existir un usuario bancario enrolado.
C02	Onboarding Controller	REST Controller	Expone endpoints de inicio, avance y finalización del proceso.	Controller	Separa contrato HTTP de la orquestación del proceso.
C03	Onboarding Orchestrator	Process Manager	Coordina consentimiento, validación, biometría, enrolamiento IdP, persistencia y eventos.	Process Manager	Centraliza la coordinación sin mezclar integraciones externas con reglas de proceso.
C04	Consent Manager	LODP Policy Component	Registra consentimiento explícito, versión del aviso, fecha/hora y aceptación biométrica.	Policy Component	Soporta trazabilidad y cumplimiento LODP antes del tratamiento de datos biométricos.
C05	Customer Data Validator	Domain Service	Valida datos mínimos, identificación, formato, duplicidad y elegibilidad básica.	Domain Service	Evita iniciar validaciones biométricas con datos insuficientes.
C06	Biometric Session Manager	Application Service	Gestiona sesión de captura biométrica, correlación y recepción del resultado.	Application Service	Mantiene la sesión biométrica desacoplada de la integración del proveedor.
C07	Biometric Provider Adapter	ACL / External Adapter	Aísla integración con proveedor biométrico para liveness detection y face match.	Anti-Corruption Layer	Permite cambiar proveedor sin contaminar el dominio interno.
C08	Enrollment Eligibility Policy	Policy Component	Evalúa continuidad del enrolamiento según biometría, riesgo y políticas de seguridad.	Policy Component	Encapsula la decisión de continuidad del proceso.
C09	Credential Enrollment Service	Application Service	Gestiona alta de usuario digital, credenciales iniciales y métodos post-onboarding.	Application Service	Separa enrolamiento de credenciales de la orquestación general.
C10	IdP Enrollment Client	OIDC/API Client	Invoca el IdP para crear o vincular identidad digital y métodos de autenticación.	Client Adapter	Mantiene controlada la integración con identidad corporativa.
C11	Onboarding State Repository	Repository	Persiste estado, consentimiento, correlación, validaciones y referencias de evidencia.	Repository	Da trazabilidad operativa y continuidad al proceso.
C12	Evidence Storage Client	AWS SDK / S3 Client	Guarda evidencia mínima cifrada; no guarda imagen facial en claro.	Secure Evidence Storage	Cumple minimización, cifrado y retención limitada.
C13	Audit Mapper	Mapping Component	Normaliza eventos de onboarding: candidato, canal, consentimiento, resultado y timestamp.	Event Mapping	Evita publicar eventos sin estructura uniforme.
C14	Event Publisher	AWS SDK Client	Publica eventos hacia Cola/Eventos para auditoría y notificaciones.	Publisher / Domain Events	Desacopla el proceso de onboarding de consumidores posteriores.

El detalle completo de relaciones de este diagrama se conserva como material complementario versionado en el repositorio.

6. Vista de Tiempo de Ejecución

Esta sección resume los principales escenarios de ejecución del sistema. No se incorporan diagramas runtime extensos en el cuerpo principal del SAD porque el alcance obligatorio del ejercicio se concentra en el Modelo C4, infraestructura, seguridad, HA/DR, monitoreo y justificación de decisiones. Los diagramas BPMN y de secuencia se conservan como material complementario editable en el archivo draw.io del repositorio.

6.1. Flujo resumido de Onboarding Biométrico

El onboarding biométrico permite registrar digitalmente a un nuevo cliente desde la aplicación móvil. El flujo prioriza el consentimiento LOPDP antes de cualquier tratamiento biométrico y luego continúa con la validación de datos mínimos, prueba de vida, verificación facial, enrolamiento en el IdP corporativo, registro de evidencia mínima cifrada, auditoría y notificación al cliente.

Paso	Responsable	Descripción	Control principal
1	Cliente / App Móvil	Ingresa datos mínimos y acepta aviso de privacidad	Consentimiento LOPDP previo
2	Servicio Onboarding	Registra consentimiento y valida datos mínimos	Trazabilidad y elegibilidad
3	Cliente / App Móvil	Captura rostro y prueba de vida	SDK biométrico
4	Proveedor Biométrico	Ejecuta liveness y verificación facial	ISO/IEC 30107-3
5	Servicio Onboarding	Evalúa resultado biométrico y reglas de seguridad	No almacenar imagen facial en claro
6	IdP Corporativo	Crea o vincula usuario digital	OAuth2/OIDC
7	Servicio Onboarding	Guarda estado final y evidencia mínima cifrada	KMS / retención limitada
8	Auditoría / Notificación	Registra evento y notifica resultado	Auditoría append-only

El detalle estructural de estos componentes se documenta en el diagrama C3-C del Servicio de Onboarding Biométrico. El flujo detallado se conserva como soporte editable en el repositorio, sin incluirlo en el cuerpo principal del SAD para mantener el documento proporcional al alcance del ejercicio.

6.2. Flujo resumido de Transferencia Interbancaria

La transferencia interbancaria es uno de los flujos más críticos del sistema, porque combina autenticación, validación de límites, prevención ALA/CFT, idempotencia, afectación contable en el Core Bancario, integración con el Banco Central del Ecuador, auditoría, notificación y conciliación ante timeout o respuesta no concluyente.

Paso	Responsable	Descripción	Control principal
1	Cliente / App Móvil	Solicita transferencia	HTTPS/TLS
2	API Gateway / BFF	Valida token, canal y rate limit	OAuth2/OIDC
3	Core Digital Backend	Enruta operación autenticada	Sesión segura

4	Servicio Transferencias	Valida idempotencia, monto, límites y beneficiario	Idempotency-key
5	Servicio Transferencias / IdP	Ejecuta step-up si hay riesgo alto	OTP / push authentication
6	Core Bancario	Valida fondos y afecta o reserva monto	ACL / REST sobre TLS
7	Servicio Transferencias	Envía operación al BCE	Mensajería BCE/TLS
8	BCE	Acepta, rechaza o no responde en tiempo esperado	Estado transaccional
9	Servicio Transferencias	Registra estado final o pendiente de conciliación	Máquina de estados
10	Auditoría / Notificación	Audita y notifica al cliente	Correlation ID

El detalle estructural de los componentes internos se presenta en el diagrama C3-B del Servicio de Transferencias. El flujo detallado queda como material complementario editable en el repositorio, mientras que el cuerpo principal del SAD conserva una vista resumida para mantener el documento proporcional al alcance del ejercicio.

6.3. Flujo resumido de Autenticación OAuth2/OIDC

Para la SPA Web se recomienda el flujo Authorization Code + PKCE con patrón BFF. El navegador redirige al IdP corporativo para la autenticación, pero el intercambio del código por tokens queda a cargo del BFF. De esta forma, los tokens no quedan expuestos en el navegador y la sesión del usuario se maneja mediante cookies HttpOnly, Secure y SameSite.

Para la App móvil se mantiene Authorization Code + PKCE conforme a RFC 8252, usando navegador externo del sistema y almacenamiento seguro en Keychain o Keystore.

Este diseño se adopta porque:

- Evita exponer tokens en localStorage.
- Usa un flujo recomendado para clientes públicos.
- Permite MFA y step-up en operaciones sensibles.
- Mantiene compatibilidad con un IdP corporativo configurable.

Los flujos runtime detallados se conservan como material complementario editable en el archivo BP_Digital_Banking_C4.drawio. En el cuerpo principal del SAD se mantiene una explicación resumida para preservar claridad y proporcionalidad del entregable.

7. Vista de Despliegue

Esta sección describe cómo los contenedores definidos en el C4 Nivel 2 se llevan a una infraestructura real. El despliegue propuesto es híbrido: los canales digitales y servicios de la BP Digital Banking Platform se ejecutan en AWS, mientras que el Core Bancario y el sistema complementario permanecen en el datacenter del banco.

La integración entre AWS y el entorno on-premise se realiza mediante Direct Connect como enlace principal y VPN como respaldo. Esta decisión reduce exposición del Core Bancario, mantiene control operativo sobre los sistemas existentes y permite evolucionar la banca digital sin reemplazar la plataforma central del banco.

7.1. Infraestructura AWS — Visión general

La región principal propuesta es sa-east-1 (Sao Paulo), por cercanía regional y menor latencia hacia Ecuador frente a regiones más lejanas. La región us-east-1 se considera como sitio de recuperación ante desastres para los componentes críticos.

La infraestructura base incluye VPC, subredes públicas y privadas entre zonas de disponibilidad, balanceador de carga, ECS Fargate para servicios de aplicación, RDS PostgreSQL Multi-AZ para datos transaccionales, ElastiCache Redis para caché, DynamoDB para auditoría, S3 para almacenamiento frío, SQS/SNS para mensajería y servicios de borde como CloudFront, WAF y Shield.

El criterio de diseño es usar servicios gestionados para reducir carga operativa, controlar costos y evitar administrar servidores directamente en esta etapa del proyecto.

7.2. Multi-AZ y Estrategia de Recuperación ante Desastres

La estrategia de alta disponibilidad se basa en Multi-AZ para los servicios críticos y en componentes gestionados de AWS. ECS Fargate permite recuperación automática de tareas, RDS Multi-AZ reduce el riesgo de indisponibilidad de base de datos y SQS/SNS desacopla procesos que no requieren respuesta inmediata.

Para recuperación ante desastres se propone un esquema activo-pasivo tipo Pilot Light hacia us-east-1. Para servicios transaccionales críticos, como autenticación, transferencias y pagos en tiempo real, se plantea un objetivo $RTO \leq 1$ hora y $RPO \leq 15$ minutos. Para servicios no críticos, como reportes históricos, descargas diferidas o analítica, se aceptan objetivos más amplios para controlar costos.

Las integraciones externas usan timeouts, reintentos controlados, circuit breakers y colas de error. En transferencias, si el Banco Central no confirma una operación, el sistema no informa éxito definitivo al cliente; deja la transacción en estado pendiente de conciliación.

8. Conceptos Transversales

Los conceptos transversales agrupan decisiones que aplican a varios contenedores y no pertenecen a una única vista C4. En esta sección se resumen los criterios comunes de seguridad, disponibilidad, observabilidad, costos, datos y cumplimiento.

El detalle de estas decisiones se apoya en las vistas C4, la vista de despliegue y la sección de decisiones arquitectónicas clave.

8.1. Seguridad

El modelo de seguridad se plantea por capas. En autenticación se usa OAuth2/OIDC con Authorization Code + PKCE, MFA y step-up para operaciones sensibles. En la SPA Web se usa el patrón BFF para evitar exposición de tokens en el navegador.

La comunicación entre componentes usa TLS 1.2 como mínimo y TLS 1.3 como preferente. Los datos en reposo se cifran con AWS KMS, usando claves administradas por servicio cuando corresponda. Los secretos se gestionan en AWS Secrets Manager con rotación controlada.

La red se segmenta con VPC, subredes públicas y privadas, grupos de seguridad y exposición pública limitada a los componentes de entrada. El perímetro se protege con CloudFront, WAF y Shield Standard. Para datos biométricos se aplican controles reforzados: consentimiento previo, minimización, cifrado, retención limitada y anonimización en logs.

En el ciclo de desarrollo se consideran controles DevSecOps como SAST, DAST, análisis de dependencias, revisión de secretos y validaciones de seguridad en CI/CD.

8.2. Alta Disponibilidad y Recuperación ante Desastres

La disponibilidad se plantea por capas. En operación normal se usa despliegue Multi-AZ para los componentes críticos, balanceo de carga, autoescalado en ECS Fargate y servicios gestionados de AWS para reducir puntos únicos de falla. Las integraciones externas usan timeouts, reintentos controlados, circuit breakers y colas de error para evitar que una falla externa afecte a todo el sistema.

Para recuperación ante desastres se propone una estrategia activo-pasivo tipo Pilot Light hacia us-east-1. Los objetivos RTO y RPO se diferencian por criticidad: autenticación, transferencias y pagos requieren recuperación más rápida, mientras que reportes históricos, analítica y procesos diferidos pueden aceptar ventanas mayores para controlar costos.

Las pruebas de continuidad se ejecutan de forma periódica mediante escenarios controlados de recuperación, validando restauración de servicios, base de datos, mensajería e integraciones principales.

8.3. Observabilidad

La observabilidad se apoya en logs, métricas y trazas. Los logs se centralizan en CloudWatch Logs, usando formato estructurado y un identificador de correlación por operación para facilitar seguimiento entre canales, backend, servicios especializados e integraciones externas.

Las métricas se publican en CloudWatch Metrics, incluyendo indicadores técnicos y de negocio: transacciones por canal, tasa de error por integración, latencia P95/P99 por endpoint y disponibilidad de servicios críticos. Para trazabilidad distribuida se considera AWS X-Ray, especialmente en flujos que cruzan BFF, Core Digital Backend, Servicio de Transferencias y sistemas externos.

Las alertas se configuran con CloudWatch Alarms y se escalan a los canales operativos definidos por el banco. Cada dominio crítico debe contar con un tablero operativo básico para revisar disponibilidad, errores, latencia y volumen transaccional.

8.4. Optimización de Costos (FinOps)

El control de costos se basa en usar servicios gestionados y escalar solo cuando la carga lo justifique. ECS Fargate evita administrar servidores directamente, SQS/SNS desacopla procesos sin mantener infraestructura propia, S3 permite almacenamiento económico por ciclo de vida y RDS Multi-AZ se reserva para datos transaccionales que requieren consistencia y alta disponibilidad.

Para cargas predecibles se consideran Savings Plans o reservas equivalentes, mientras que para horarios de baja demanda se aplica autoescalado. El almacenamiento histórico se mueve a clases de menor costo mediante políticas de ciclo de vida.

La evolución tecnológica debe estar condicionada por umbrales medibles. Servicios más complejos, como Kubernetes administrado o plataformas de streaming dedicadas, solo se justifican si el volumen, la concurrencia o la criticidad operativa superan la capacidad del diseño inicial.

8.5. Gestión de Datos y Patrones de Persistencia

La persistencia se separa según el tipo de dato y el patrón de acceso. Los datos operacionales se almacenan en PostgreSQL sobre RDS Multi-AZ, por su consistencia, soporte relacional y facilidad de auditoría transaccional. La auditoría append-only y eventos de alto volumen se apoyan en DynamoDB, mientras que Redis en ElastiCache se usa para caché y datos temporales de consulta frecuente.

Los archivos, evidencias y almacenamiento frío se gestionan en S3, aplicando cifrado, versionamiento y políticas de ciclo de vida. Los respaldos se cubren con backups automáticos de RDS, snapshots controlados, PITR en DynamoDB cuando aplique y políticas de retención acordes al tipo de información y a la normativa bancaria y de protección de datos aplicable.

Los patrones principales son Repository para acceso controlado a datos, Cache-Aside para consultas frecuentes y separación básica entre operaciones transaccionales y consultas pesadas cuando sea

necesario. No se propone una arquitectura CQRS completa en esta etapa para evitar complejidad innecesaria.

8.6. Cumplimiento Operativo

El cumplimiento operativo se considera desde el diseño de la plataforma. El sistema genera eventos transaccionales y evidencias auditables que pueden alimentar procesos de control, revisión y reporte regulatorio, incluyendo reportes RESU y ROS conforme a los formatos y plazos establecidos por la UAFE vigente.

Las notificaciones al cliente se integran con la salida transaccional y pueden ejecutarse por los canales habilitados por el banco, de acuerdo con la criticidad de la operación y la política institucional. Para operaciones sensibles, como transferencias, cambios de credenciales o enrolamiento biométrico, se registra evidencia de notificación y resultado.

El consentimiento LOPDP se registra con sello de tiempo, versión del aviso aceptado, canal de aceptación y trazabilidad de auditoría. La gestión de derechos del titular, como acceso, rectificación, eliminación, oposición y demás derechos aplicables, se atiende mediante procesos definidos por el banco y con soporte de evidencia en el Servicio de Auditoría.

La respuesta a requerimientos de autoridades se canaliza a través del área de cumplimiento, evitando accesos directos no controlados a la información. Toda extracción, revisión o entrega de evidencia debe quedar registrada para mantener trazabilidad y responsabilidad operativa.

9. Decisiones arquitectónicas clave

Esta sección resume las decisiones técnicas que más peso tienen en el diseño. No se usa un formato de registro extenso porque el ejercicio no lo solicita. Lo importante aquí es dejar claras las opciones evaluadas, la decisión tomada y las razones principales que la sostienen.

Decisión 1 — Monolito modular con servicios extraídos

Opciones evaluadas: microservicios completos desde el inicio, monolito tradicional sin separación interna, y monolito modular con servicios separados solo cuando existe una razón fuerte para hacerlo.

Justificación: La razón principal es el costo operativo. Arrancar con microservicios completos exige más infraestructura, más monitoreo, más despliegues independientes y más coordinación entre equipos. Para el volumen inicial del MVP, ese costo no compensa. **La segunda** razón es evolutiva: si el monolito se organiza por dominios claros, se puede extraer un servicio más adelante sin rehacer todo el sistema.

Riesgo o consecuencia principal: El riesgo es que con el tiempo se pierda la disciplina de separación entre módulos y el monolito termine acoplado internamente. Para reducir ese riesgo, se propone mantener paquetes por dominio, dependencias explícitas y revisiones de código enfocadas en evitar acoplamiento innecesario.

Decisión 2 — AWS ECS Fargate para el MVP

Opciones evaluadas: AWS EKS, AWS ECS Fargate y AWS App Runner.

Justificación: La opción elegida es ECS Fargate porque permite ejecutar contenedores sin administrar servidores ni nodos directamente. Esto reduce carga operativa, superficie de mantenimiento y esfuerzo de administración para una primera versión del sistema. **La segunda** razón es de costo y operación, para el volumen inicial estimado, EKS puede ser más flexible, pero también exige mayor gobierno técnico, configuración de clúster, monitoreo y operación especializada. En esta fase no se justifica pagar esa complejidad si Fargate cubre el despliegue, escalado y aislamiento que necesita el MVP.

Riesgo o consecuencia principal: Si en el futuro la plataforma necesita mayor control sobre la infraestructura, redes internas más complejas o patrones avanzados de operación, se podría evaluar una migración hacia EKS. Esa decisión debería tomarse solo cuando la carga, el equipo operativo o la criticidad del sistema lo justifiquen.

Decisión 3 — Mensajería con AWS SQS y SNS

Opciones evaluadas: RabbitMQ autohospedado, Apache Kafka/MSK y AWS SQS + SNS.

Justificación: La opción elegida es SQS + SNS porque permite desacoplar procesos sin administrar un broker propio. Para este MVP, la mensajería se usa principalmente para auditoría, notificaciones y eventos de negocio que no deben bloquear la transacción principal. **La segunda** razón es operativa y de costos, al

ser servicios gestionados, se reduce la carga de mantenimiento, respaldos, parches y alta disponibilidad de una plataforma de mensajería propia. Además, el modelo de pago por uso encaja mejor con una carga inicial variable.

Riesgo o consecuencia principal: SQS y SNS cubren bien el desacoplamiento inicial, pero no reemplazan una plataforma de streaming avanzada. Si en el futuro el banco requiere reprocesamiento masivo de eventos, analítica en tiempo real o integración por eventos a gran escala, se debería evaluar MSK/Kafka.

Decisión 4 — Patrón BFF para la SPA Web

Opciones evaluadas: SPA con tokens en localStorage, SPA con tokens en sessionStorage y SPA con BFF usando cookies de sesión seguras.

Justificación: La opción elegida es usar BFF porque evita que los tokens de acceso queden expuestos directamente en el navegador. Esto reduce el impacto de ataques XSS y permite manejar la sesión del usuario con cookies HttpOnly, Secure y SameSite. **La segunda** razón es que el BFF permite adaptar las APIs internas al canal web sin exponer directamente la estructura del backend. En una aplicación bancaria esto ayuda a controlar mejor autenticación, autorización, sesión, trazabilidad y validaciones por canal.

Riesgo o consecuencia principal: Se agrega un componente más a operar y monitorear. Sin embargo, para una SPA bancaria, ese costo se justifica por la mejora en seguridad y control de sesión.

Decisión 5 — React + TypeScript en web; Flutter en móvil

Opciones evaluadas: para la SPA Web se evaluó React 18 + TypeScript frente a Angular. Para la aplicación móvil se evaluó Flutter frente a React Native.

Justificación: En la parte web se elige React + TypeScript porque permite construir una SPA mantenible, con tipado, buena integración con el patrón BFF y una curva de adopción razonable para equipos que ya trabajan con JavaScript. Angular también es una opción válida, pero para este MVP introduce más estructura y curva de aprendizaje de la necesaria. **En la parte móvil** se elige Flutter porque permite mantener una sola base de código para iOS y Android, con una experiencia visual consistente y buen soporte para integraciones nativas como biometría local, almacenamiento seguro y notificaciones. React Native también es válido, especialmente si el equipo ya domina JavaScript, pero Flutter ofrece mayor control visual y menor dispersión entre plataformas para este caso.

Riesgo o consecuencia principal: La decisión exige definir estándares internos de desarrollo para no dejar que cada equipo implemente el frontend a su manera. En web se deben fijar reglas de routing, manejo de estado, formularios y consumo del BFF. En móvil se debe cuidar la integración con SDKs nativos y la seguridad del almacenamiento local.

Decisión 6 — OAuth 2.0 Authorization Code con PKCE

Opciones evaluadas: Authorization Code + PKCE, Implicit Flow, Resource Owner Password Credentials, Client Credentials y Device Code.

Justificación: La opción elegida es Authorization Code con PKCE porque es el flujo más adecuado para clientes públicos como la SPA Web y la aplicación móvil. PKCE reduce el riesgo de interceptación del código de autorización, especialmente en escenarios donde no se puede proteger un client secret como en una aplicación web del lado del cliente o una app móvil. **La segunda** razón es de seguridad y gobierno. Este flujo permite integrarse con el IdP corporativo existente, aplicar MFA, step-up authentication y mantener separación entre autenticación, autorización y lógica de negocio. Además, evita usar flujos menos recomendados para este caso, como Implicit Flow o Resource Owner Password Credentials.

Riesgo o consecuencia principal: El flujo requiere redirecciones hacia el IdP. En móvil se debe usar el navegador externo del sistema, conforme a buenas prácticas para aplicaciones nativas. Esto puede agregar un paso adicional en la experiencia de usuario, pero en banca se justifica por seguridad y control de sesión.

Decisión 7 — Patrón Saga para transferencias

Opciones evaluadas: Transacción distribuida con 2PC, Saga coreografiada por eventos y Saga orquestada con un coordinador central.

Justificación: Se elige Saga orquestada porque permite controlar el flujo completo de la transferencia desde un componente claro, facilitando trazabilidad, manejo de errores y seguimiento del estado de la operación. Esto es importante porque una transferencia puede pasar por varios sistemas: Core Bancario, Banco Central, auditoría y notificaciones. La segunda razón es que 2PC no es una opción realista cuando intervienen sistemas externos que no están bajo control directo del banco. Con Saga, cada paso puede tener una acción de compensación o conciliación, reduciendo el riesgo de dejar operaciones en estados inconsistentes.

Riesgo o consecuencia principal: El diseño exige definir bien los estados de la operación y las acciones de compensación. Esto agrega complejidad, pero es una complejidad necesaria para manejar transferencias con sistemas externos y posibles timeouts.

Decisión 8 — Cache-Aside para clientes frecuentes

Opciones evaluadas: Cache-Aside, Read-Through, Write-Through, Write-Behind y Refresh-Ahead.

Justificación: Se elige Cache-Aside porque permite usar Redis como una capa de aceleración sin convertirlo en la fuente principal de datos. Si la caché no tiene el dato o presenta un fallo, el backend puede consultar directamente al Core Bancario mediante el repositorio y la capa de integración. **La segunda** razón es que este patrón reduce carga sobre el Core y mejora el tiempo de respuesta en consultas frecuentes, como posición consolidada, saldos y últimos movimientos. Además, no exige cambios en el

Core existente, lo cual es importante porque el ejercicio plantea que la información del cliente proviene de sistemas ya existentes.

10. Requisitos de calidad considerados

Esta sección resume los principales atributos de calidad considerados en el diseño y muestra en qué partes del documento se atienden. El objetivo es evidenciar que la arquitectura no solo cubre funcionalidad, sino también seguridad, disponibilidad, monitoreo, costos, cumplimiento y tolerancia a fallos.

Atributo de calidad	Cómo lo atiende el diseño	Dónde se ve
Seguridad	OAuth2/OIDC con PKCE, BFF para SPA, MFA y step-up, cifrado con TLS y AWS KMS, WAF y Shield en el borde, segregación de redes.	Sección 4.2, Sección 8.1
Alta disponibilidad	Multi-AZ para componentes críticos, ECS Fargate con recuperación automática, balanceo de carga, circuit breakers, reintentos controlados y colas de error	Sección 7.2, Sección 8.2
Recuperación ante desastres	Estrategia activo-pasivo tipo Pilot Light hacia us-east-1, con RTO y RPO diferenciados según criticidad del servicio.	Sección 7.2
Monitoreo y observabilidad	Logs centralizados, métricas técnicas y de negocio, trazas distribuidas, tableros operativos y alertas sobre servicios críticos.	Sección 8.3
Manejo de costos	Uso de servicios gestionados y bajo demanda, autoescalado, almacenamiento por ciclo de vida, revisión periódica de capacidad y evolución tecnológica por umbrales.	Sección 8.4
Cumplimiento normativo	Eventos transaccionales para auditoría y soporte a reportes regulatorios, trazabilidad LOPDP, consentimiento versionado y retención según normativa aplicable	Sección 2.3, Sección 8.6
Tolerancia a fallos	Procesamiento asíncrono con SQS/SNS, degradación controlada, aislamiento de fallos por adaptador y manejo de timeouts en integraciones externas	Sección 3.2, Sección 8.2

11. Riesgos identificados

Los siguientes riesgos son los que pueden afectar la operación, seguridad o evolución de la arquitectura propuesta. Se declaran de forma explícita junto con su mitigación o plan de salida, para que no queden como supuestos ocultos del diseño.

Riesgo	Impacto	Probabilidad	Mitigación / plan
Dependencia del proveedor biométrico externo	Alto. Puede afectar el onboarding si el proveedor presenta indisponibilidad o cambia sus condiciones de servicio.	Media	Encapsular la integración mediante ACL/adaptador, definir contrato y SLA, mantener SDK aislado y documentar plan de cambio de proveedor.
Latencia del Core Bancario on-premise	Medio. Puede degradar la experiencia del usuario en consultas frecuentes.	Media	Usar Cache-Aside para datos de lectura frecuente, Direct Connect como enlace principal, VPN como respaldo, timeouts y circuit breakers.
Cambios regulatorios BCE / UAFE	Alto. Puede obligar a ajustar adaptadores, reportes o reglas de validación.	Alta	Mantener adaptadores aislados para BCE y UAFE, generar eventos auditables para

			reportes y evitar que cambios regulatorios afecten directamente al dominio central.
Antifraude dentro del Core Digital Backend en el MVP	Medio. Puede limitar reutilización si otros canales requieren consumir la misma capacidad antifraude.	Media	Mantener el componente con interfaz definida y bajo acoplamiento, dejando explícito el umbral para extraerlo como servicio independiente cuando aparezca un segundo canal consumidor.
DR activo-pasivo como decisión inicial de costo	Medio. Reduce costos, pero no ofrece cero indisponibilidad para todos los servicios.	Baja	Definir RTO/RPO por criticidad, ejecutar pruebas periódicas de recuperación y evaluar evolución a activo-activo solo si el negocio lo justifica.
Sobrecosto cloud si el escalado no se controla	Medio. La factura puede crecer si el autoescalado no tiene límites claros.	Media	Definir límites de autoescalado, alertas de presupuesto, revisión mensual de costos y políticas de apagado o reducción para ambientes no productivos.

12. Glosario

Glosario reducido a los términos de dominio bancario ecuatoriano y a los patrones de diseño más mencionados en el documento. Los términos generales de infraestructura (TLS, VPC, WAF, CDN, etc.) no se incluyen porque se sobreentienden para el lector técnico.

Término / sigla	Definición
LOPDP	Ley Orgánica de Protección de Datos Personales del Ecuador. En este documento se usa como referencia para consentimiento, minimización, trazabilidad del tratamiento, derechos del titular y protección reforzada de datos sensibles como la biometría.
UAFE	Unidad de Análisis Financiero y Económico. Entidad ecuatoriana relacionada con la prevención, detección y reporte de operaciones vinculadas a lavado de activos y financiamiento de delitos.
RESU / ROS	Reportes gestionados ante UAFE. RESU corresponde a operaciones o transacciones individuales o múltiples que igualan o superan el umbral legal aplicable. ROS corresponde a operaciones sospechosas o que no guardan relación con el perfil económico y transaccional del cliente.
BCE	Banco Central del Ecuador. En esta arquitectura se considera como sistema externo para transferencias interbancarias y pagos en tiempo real.
SPI / SPL / SCI	Sistemas o mecanismos del ecosistema de pagos del BCE considerados dentro del contexto de interoperabilidad de pagos y transferencias.
BCE-GG-008-2025	Resolución administrativa del BCE relacionada con interoperabilidad de transferencias electrónicas de dinero para pagos en tiempo real, mensajería estandarizada y adaptación de soluciones de pago al estándar definido por el BCE.
SB-2021-2126	Resolución de la Superintendencia de Bancos relacionada con la norma de control para la gestión del riesgo operativo en entidades financieras.
OAuth2 / OIDC	OAuth2 permite delegar autorización y OpenID Connect agrega una capa de identidad federada sobre OAuth2.
PKCE	Proof Key for Code Exchange. Extensión del flujo Authorization Code que reduce el riesgo de interceptación del código en clientes públicos como SPA y aplicaciones móviles.
BFF	Backend for Frontend. Patrón en el que un backend específico atiende a un canal, por ejemplo la SPA Web, y ayuda a manejar sesión, seguridad y adaptación de APIs.
ACL	Anti-Corruption Layer. Patrón que aísla el dominio propio frente a modelos, contratos o estructuras de sistemas externos.

Saga	Patrón para coordinar procesos distribuidos mediante pasos controlados, estados y acciones de compensación o conciliación cuando una transacción distribuida tradicional no es viable.
Cache-Aside	Patrón de caché donde la aplicación consulta primero la caché; si el dato no existe o expiró, consulta la fuente autoritativa y actualiza la caché con un tiempo de vida definido.
Proveedor biométrico	Sistema externo usado para validación facial, prueba de vida o verificación de identidad. En la arquitectura se mantiene encapsulado mediante adaptador para evitar dependencia directa de un proveedor específico.
ISO/IEC 30107-3	Estándar internacional relacionado con detección de ataques de presentación en sistemas biométricos, usado como referencia para prueba de vida o liveness detection.